

UF4

Seguridad activa

Ciberseguridad

ÍNDICE

Introducción.....	05
Objetivos.....	06
Mapa conceptual	07
1. Seguridad activa.....	08
1.1. Planes de contingencia para fallos de seguridad	08
A. Tipos de hackers	09
B. Fallos de seguridad	11
C. Planes de contingencia.....	13
D. Seguridad en entornos de nube y dispositivos móviles	19
1.2. Implementación de mecanismos para verificar el origen y la autenticidad de las aplicaciones.....	19
A. Aplicación del algoritmo MD5 o funciones HASH	21
1.3. Implementación de métodos para la recuperación de datos.....	22
A. Backups.....	22
B. Recuperación de datos sin respaldo	23
1.4. Métodos de identificación: firma electrónica y certificado digital.....	26
A. Certificado digital	26
B. Firma electrónica	28
1.5. Emisión de identificaciones electrónicas y aplicación de la firma digital	29
A. Proceso de obtención de un certificado digital	30

2. Señales de alerta y riesgos de seguridad	33
2.1. Identificación y solución de problemas	34
A. Control de incidencias	35
B. Solución de problemas siguiendo las indicaciones adecuadas	35
2.2. Comprensión y uso de la documentación técnica como soporte....	38
2.3. Registro y reporte de incidentes de seguridad	40
3. Seguridad frente a software malicioso	42
3.1. Virus	44
A. Virus de sector de arranque.....	44
B. Virus de script.....	44
C. Secuestrador del navegador.....	45
D. Virus residentes.....	45
E. Virus de acción directa.....	45
F. Virus que infecta archivos.....	46
G. Virus multipartitos	46
3.2. Gusanos o worms	48
3.3. Caballos de Troya	49
3.4. Bombas lógicas.....	50
3.5. Falsas alarmas o hoaxes	50
3.6. Spyware	50
A. Formas de instalación del spyware	51
B. Hackers y métodos maliciosos.....	52
3.7. Características comunes, peligrosidad y propagación.....	53
3.8. Formas y estrategias que emplea el malware para atacar	55
A. Unidades de disco portátiles (discos, pendrives, tarjetas SD, etc.)	55
B. Redes locales de ordenadores.....	56
C. Internet.....	56
3.9. Métodos de infección.....	57

3.10. Circunstancias en las que tu sistema está en riesgo	
de ser infectado y cómo evitarlo	57
A. Consejos prácticos y fáciles.....	58
B. Consejos generales para navegar seguro.....	58
C. Protección contra gusanos (worms)	59
D. Servicios de correo con protección antivirus	59
E. Protección contra virus de macros en documentos.....	59
3.11. Antivirus	60
Solucionario casos prácticos	64
Enlaces de interés	71
Glosario	73
Bibliografía	78

Introducción

La seguridad activa es la primera línea de defensa en cualquier infraestructura tecnológica. En sistemas informáticos incluye el uso de herramientas como antivirus, firewalls, sistemas de detección de intrusos (IDS/IPS) y actualizaciones constantes que protegen contra amenazas emergentes, así como planes de contingencia y técnicas para la gestión de incidentes y la recuperación de datos frente a ciberataques.

¿Estás preparado para actuar frente a una crisis de seguridad? Los planes de contingencia son esenciales para mitigar el impacto de incidentes críticos. Aprenderás a identificar amenazas, planificar respuestas efectivas y garantizar la recuperación rápida de los sistemas. Evaluar riesgos y realizar simulacros de ciberseguridad te permitirá reconocer vulnerabilidades antes de que sean explotadas. La capacitación continua es clave para mantenerte actualizado en un entorno digital en constante cambio. Serás un profesional capaz de implementar estrategias de seguridad activa, gestionar incidentes críticos y liderar planes de contingencia.

Objetivos

X

Identificar los fallos de seguridad más comunes y aprender a evitarlos o reducir su impacto.

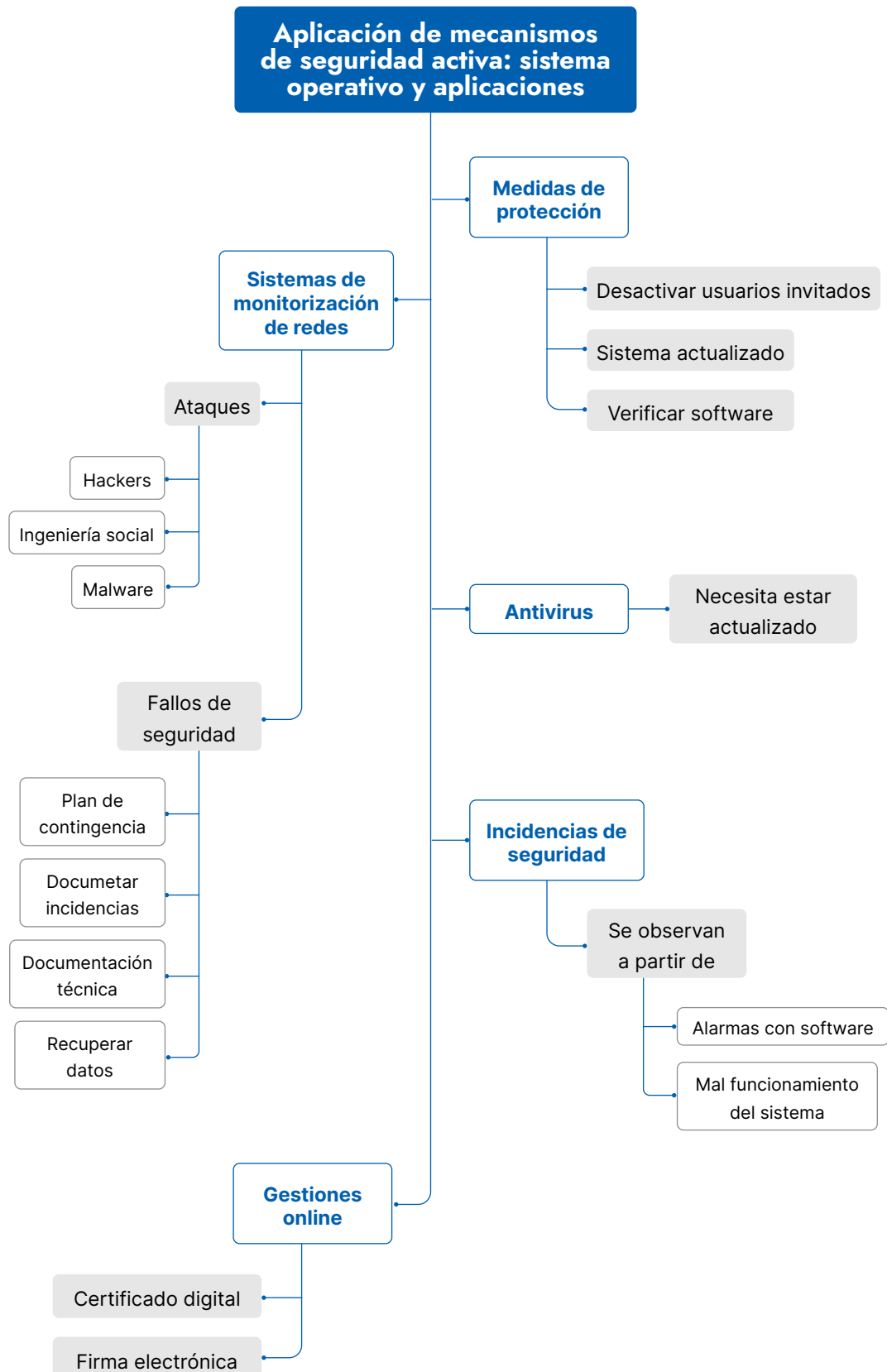
X

Conocer los tipos de ataques más frecuentes y cómo protegerse frente a ellos.

X

Instalar, configurar y mantener actualizado un antivirus para prevenir, en la medida de lo posible, la entrada de malware en el sistema.

Mapa conceptual



01 Seguridad activa

La seguridad activa incluye distintas **herramientas**; entre otras, las siguientes:

- » Programas antivirus.
- » Programas que rastrean el tráfico de información por medio de la red.
- » Configuración de los sistemas operativos y de las diferentes aplicaciones.
- » Realización de copias de seguridad tanto de los datos como de la configuración del mismo sistema.
- » Herramientas de control y verificación del software y las actualizaciones correspondientes.
- » Certificaciones digitales y otras utilidades.

Todos estos elementos configuran la parte de la seguridad informática conocida como seguridad activa, que está destinada a disminuir los efectos nocivos en los sistemas y a recuperar estos sistemas de la manera más rápida posible.

En este aspecto de la seguridad, esta tiene que estar destinada a actuar sobre una serie de elementos del sistema informático, como son **el sistema operativo, las aplicaciones, los planes de contingencia en caso de fallos de seguridad, la recuperación de datos y, de una manera muy especial, las intrusiones de virus** y otros elementos nocivos para los sistemas de computación.

1.1. Planes de contingencia para fallos de seguridad

Todos los sistemas de computación están **expuestos a amenazas** de hackers, crackers, piratas telefónicos (phreakers) o wannabes, entre otros, que, mediante las intrusiones en el sistema, producen importantes fallos de seguridad, a través de instrumentos tales como la instalación de virus, troyanos, gusanos, programas espía (spyware), los ataques de phishing y los envíos masivos de correos basura (spam) que deterioran de una forma importante el funcionamiento y la integridad del sistema.

A. Tipos de hackers

Los ataques y las intrusiones de los hackers pueden ir desde la simple **obtención de información** hasta la **supresión de datos** o a la toma de control de la máquina. De la misma manera, los virus y el resto de software malicioso pueden retardar el funcionamiento del dispositivo, colapsar el correo o bien acabar impidiendo que la máquina funcione de forma correcta.

IMPORTANTE

Se debe tener en cuenta que la seguridad total **no existe** y que siempre habrá alguien capaz de superar todas las barreras y entrar en un sistema. Es obligatorio mantener la seguridad de los sistemas informáticos e intentar prevenir siempre las situaciones de riesgo de la mejor manera posible. En este sentido, la seguridad empezará con la instalación y configuración correcta del sistema operativo.

Actualmente, disponemos de dos tipos de sistemas operativos: los sistemas operativos **propietarios** (ej.: Windows) y los sistemas operativos **de software libre** (ej.: Ubuntu). Además de las diferencias propias en la producción y el uso de cada sistema y del hecho de que uno es de pago y el otro no, también hay diferencias entre ambos en cuanto a la seguridad y la protección frente a virus o malware.

Una vez escogido e instalado el sistema operativo en el ordenador, habrá que **configurarlo** correctamente. Para hacerlo, ve al centro de seguridad y activa las actualizaciones del sistema para que siempre tenga las últimas versiones. Cuando crees los usuarios, solo tienes que darles los privilegios necesarios para que puedan hacer las tareas pertinentes. Igualmente, escogerás cómo deben ser las contraseñas para estos usuarios. Tienes que intentar que sean difíciles para evitar que alguien con un ataque de fuerza bruta las descifre.



¿SABÍAS QUE...?

Además, hay una multitud de opciones de configuración del sistema que deberás tener en cuenta. Por ejemplo, en los sistemas Windows, podrás activar la opción de visualizar siempre las extensiones de los archivos. De esta manera, cuando recibas un correo electrónico con un archivo adjunto, aunque supuestamente sea de un contacto de confianza y el archivo tenga un icono conocido (como por ejemplo la de un archivo del procesador de textos Word), si ves que tiene una extensión .exe, no harás doble clic sobre él y lo abrirás, puesto que probablemente contenga un **código malicioso** que se ejecutaría en el momento de abrirlo.

Tal y como hemos visto anteriormente, los sistemas operativos ofrecen la posibilidad de **crear y automatizar las copias de seguridad**, tanto para los datos guardados como para la misma configuración del sistema. De este modo, podrás recuperar el sistema de una forma más rápida y devolverlo a la configuración personalizada.

Finalizada la instalación del sistema operativo, se procede a **instalar las aplicaciones**. Una sencilla pero excelente medida de seguridad consiste en instalar solo las aplicaciones que necesites. Las debes tener controladas, porque, si en algún momento detectas una aplicación que no habías instalado, sabrás que se trata de una intrusión. Además, debes asegurarte de que las aplicaciones que instalas son auténticas y tienen la licencia correspondiente (se aconseja descargarlas solo de sitios oficiales). Asimismo, es conveniente que mantengas las aplicaciones actualizadas para evitar agujeros de seguridad.

Seguidamente, instalarás y mantendrás actualizado un programa antivirus. Este es un software diseñado para detectar, **prevenir y eliminar malware** como troyanos, gusanos, spyware y otras amenazas informáticas que pueden comprometer la seguridad de los dispositivos y la privacidad de los usuarios.



WEB

Para saber más sobre antivirus:

<https://www.incibe.es/ciudadania/tematicas/configuraciones-dispositivos/antivirus>

A continuación, debes hacer lo mismo con el **cortafuegos** (firewall), que es un sistema que supervisa y controla el tráfico de la red en base a un conjunto de reglas de seguridad.

Los antivirus suelen desplegar diferentes **técnicas** para conseguir su objetivo, aunque las dos más importantes son estas:

Examinar

(escanear) archivos para buscar virus conocidos que se ajusten a las definiciones recopiladas en una base de datos de virus.



Identificar

comportamientos sospechosos de cualquier software que puedan sugerir un posible problema. Este examen puede incluir análisis de datos, monitorización y captura de datos, entre otras técnicas.

La mayoría de los antivirus actuales utilizan ambas técnicas; especialmente, la de la base de datos de software malicioso. Es posible incluso ir más allá y controlar qué puertos tiene abiertos el sistema. De este modo, puedes indicar **que solo estén abiertos los que realmente necesitas** para trabajar, cosa que dificulta la entrada de intrusos. Igualmente, puedes poner contraseñas en las carpetas o encriptar la información sensible.

Además, en entornos empresariales, es necesario garantizar la **protección de los datos personales** para evitar sanciones legales y pérdidas de confianza de los clientes. Según el Reglamento General de Protección de Datos (RGPD) y la Ley Orgánica de Protección de Datos (LOPD), las organizaciones deben implementar las medidas de seguridad adecuadas para proteger la información de sus usuarios y clientes.

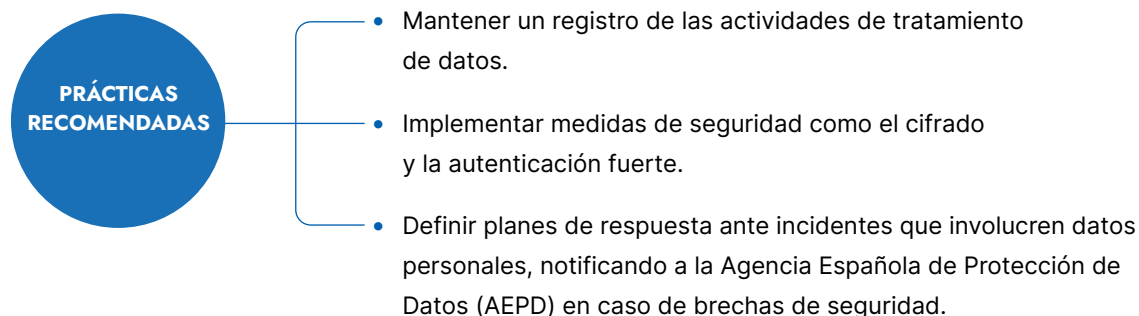


WEB

Reglamento General de Protección de Datos (RGPD):

<https://www.boe.es/doue/2016/119/L00001-00088.pdf>

Entre las **prácticas** recomendadas se incluyen:



Todas estas actuaciones ayudarán a impedir o minimizar los ataques externos a tu sistema. ¿Pero qué sucede si no puedes evitar los efectos del software malintencionado o las intrusiones de hackers que han conseguido saltarse todas las barreras? Hay una parte de la seguridad activa que actúa en estas situaciones; se trata de los **planes de contingencia**. Hace falta que estés prevenido para actuar en las situaciones en las que el sistema ha sido vulnerado para minimizar daños y recuperar la normalidad lo más rápido posible.

B. Fallos de seguridad

Los errores en la seguridad pueden afectar tanto al hardware como al software, aunque lo normal es que afecten a los datos que tienes guardados en el sistema, puesto que estos serán, en la mayoría de los casos, el objetivo de los posibles ataques externos.



¿SABÍAS QUE...?

Normalmente, en ordenadores comerciales, **la mayoría de los errores de seguridad se producen en los navegadores, el correo electrónico, las suites ofimáticas y las aplicaciones de reproducción multimedia**. En cambio, en los servidores, la mayoría de los problemas de seguridad los encontramos en los servicios de **aplicaciones web, las herramientas de administración de los servidores y el software de bases de datos**. Hay en particular algunas aplicaciones, como las de mensajería instantánea y las de compartición de archivos P2P (menos usada en la actualidad) o descarga de apps, que son una fuente importante de entrada de virus y programas maliciosos.

En la actualidad, la distribución de malware ha evolucionado. Aunque en el pasado las redes P2P fueron un vector de infección importante, hoy en día las técnicas más utilizadas incluyen:

Phishing	Ataques a través de correos electrónicos o mensajes falsos que buscan engañar a los usuarios para robar credenciales o descargar malware.
Redes sociales	Campañas de engaño mediante enlaces maliciosos disfrazados de publicaciones atractivas o de falsas promociones.
Adjuntos de correo infectados	Archivos que parecen inofensivos, pero contienen código malicioso que se activa al ser abiertos.
Malware en aplicaciones móviles	Muchas aplicaciones fraudulentas contienen código malicioso que compromete la seguridad del usuario.

Mantener las aplicaciones instaladas **debidamente actualizadas** con los últimos parches de seguridad es un primer paso para mejorar la seguridad de nuestro sistema. El siguiente paso es instalar y actualizar un antivirus y un cortafuegos tal y como hemos comentado anteriormente. Los fallos más simples de seguridad permitirán ataques fatídicos a nuestro sistema. Es posible que se detecten rápidamente si consisten, por ejemplo, en cambiar el contenido de una página web o la hora del sistema. Por desgracia, también es posible que los efectos del ataque no se detecten hasta después de mucho tiempo o que incluso no se descubran nunca. Es muy importante detectar de forma rápida un ataque para minimizar sus efectos y restaurar el sistema cuanto antes.

Los efectos de los ataques producidos por una brecha de seguridad pueden ser **muy diversos**, yendo desde la apropiación de información hasta la instalación de programas nocivos, pasando por la alteración del sistema operativo o de algunas de las aplicaciones instaladas. Estas acciones pueden ser especialmente sensibles si se producen en empresas o instituciones con multitud de datos personales susceptibles.

Es de vital importancia **evitar todos estos errores de seguridad**, puesto que las consecuencias que se deriven de ellos serán muy relevantes. De todos modos, no es fácil impedirlos. Incluso los sistemas que cuentan con una mayor seguridad, como los de la NASA, los departamentos de defensa y sanidad o los grandes bancos, alguna vez han sufrido ataques de hackers que han conseguido robar información.



VIDEO

Vídeo sobre los **ciberataques más famosos de la historia**:

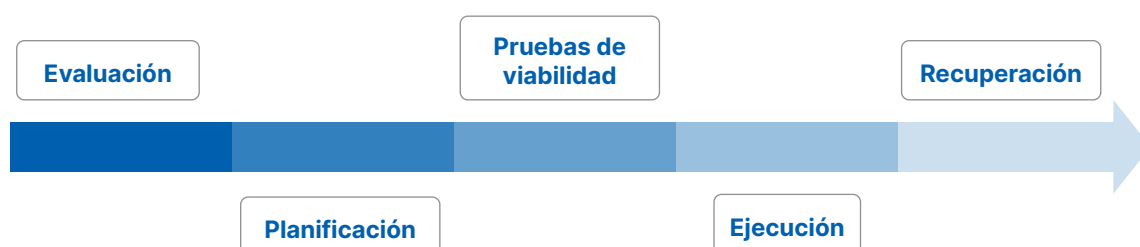
https://www.youtube.com/watch?v=8-MPekrc_QA

C. Planes de contingencia

Cuando detectamos una intrusión, el **sistema suele tener problemas y mostrar los efectos de haberla sufrido**. Hace falta disponer de mecanismos para minimizar los efectos del ataque y recuperar el sistema cuanto antes. Una herramienta que nos puede ayudar son los planes de contingencia. Estos tienen una importancia crucial para las empresas o las instituciones, puesto que es en ellas donde los efectos de un ataque pueden tener más impacto.

Podemos definir un **plan de contingencia** como el conjunto de procedimientos alternativos diseñados para mantener la operatividad de una empresa ante situaciones que interrumpen su funcionamiento normal. Su principal objetivo es garantizar la continuidad de las operaciones, incluso cuando alguna de las funciones clave se vea afectada por un incidente, ya sea de origen interno o externo a la organización.

Este plan de continuidad operativa tiene que consistir en una **estrategia** que permita a la empresa o la institución seguir funcionando cuando haya alguna incidencia de seguridad. A la vez, tiene que dar instrucciones que indiquen cómo se debe resolver y de qué manera hay que actuar. Así pues, la existencia de este plan es fundamental y, en caso de que no se tuviera, elaborarlo será una prioridad máxima. El hecho de preparar un plan de contingencia no implica reconocer que la gestión de la empresa es deficiente. Por el contrario, representa un gran avance para superar las diversas situaciones de riesgo que podrían generar pérdidas significativas. Estos riesgos no solo pueden ocasionar la pérdida de materiales, sino también la interrupción de las operaciones del negocio durante un periodo de tiempo importante. Las personas responsables de llevar a cabo el plan deben conocer su alcance para seguir las instrucciones de una manera rápida y eficiente. La elaboración de un plan de contingencia constará de las siguientes **fases**:



Las tres primeras fases de la elaboración hacen referencia a la **parte preventiva**: analizar y evaluar los riesgos del sistema en cuestión, hacer una planificación de las acciones que se tienen que llevar a cabo para protegerlo y comprobar su eficacia mediante las pruebas de viabilidad. Las dos que quedan se refieren a la **ejecución del plan** una vez que ya ha ocurrido el siniestro en el sistema: qué pasos se tienen que seguir cuando se ha detectado un ataque y cómo se efectuará la recuperación de la plataforma tecnológica.

La evaluación, la planificación y las pruebas de viabilidad dependerán de cada sistema en particular. De este modo, para llevarlas a cabo, se deberá tener en cuenta de qué elementos consta el entorno digital, qué datos hay que proteger, etc.

Ahora veremos un ejemplo práctico de los dos últimos puntos de un plan de contingencia en una **arquitectura sencilla**, como la que podríamos tener cualquiera de nosotros en casa o la de una empresa pequeña. Como se ha comentado, estos dos últimos puntos hacen referencia a las actuaciones que hay que poner en marcha cuando se detecta una intrusión en el sistema.

La intrusión puede detectarse cuando, por ejemplo, el ordenador presenta un comportamiento inusual, desaparecen archivos u opera de forma mucho más lenta, entre otros indicios. Ante la sospecha de un posible ataque que afecte al sistema, es fundamental actuar con rapidez, ya que siempre es preferible prevenir mayores daños.

Para realizar una **contención y un análisis del ataque informático**, debemos seguir estos pasos:

1

La primera medida que debemos tomar es **aislar el ordenador** para evitar que el atacante continúe operando. Para hacerlo, cerraremos todas las aplicaciones que se están ejecutando en el ordenador y guardaremos los archivos de datos utilizados por estas aplicaciones.

2

En caso de que el equipo comprometido sea un **servidor**, es necesario detener temporalmente todos los servicios y recursos en ejecución. De esta manera, evitaremos la propagación del ataque a los equipos cliente.

3

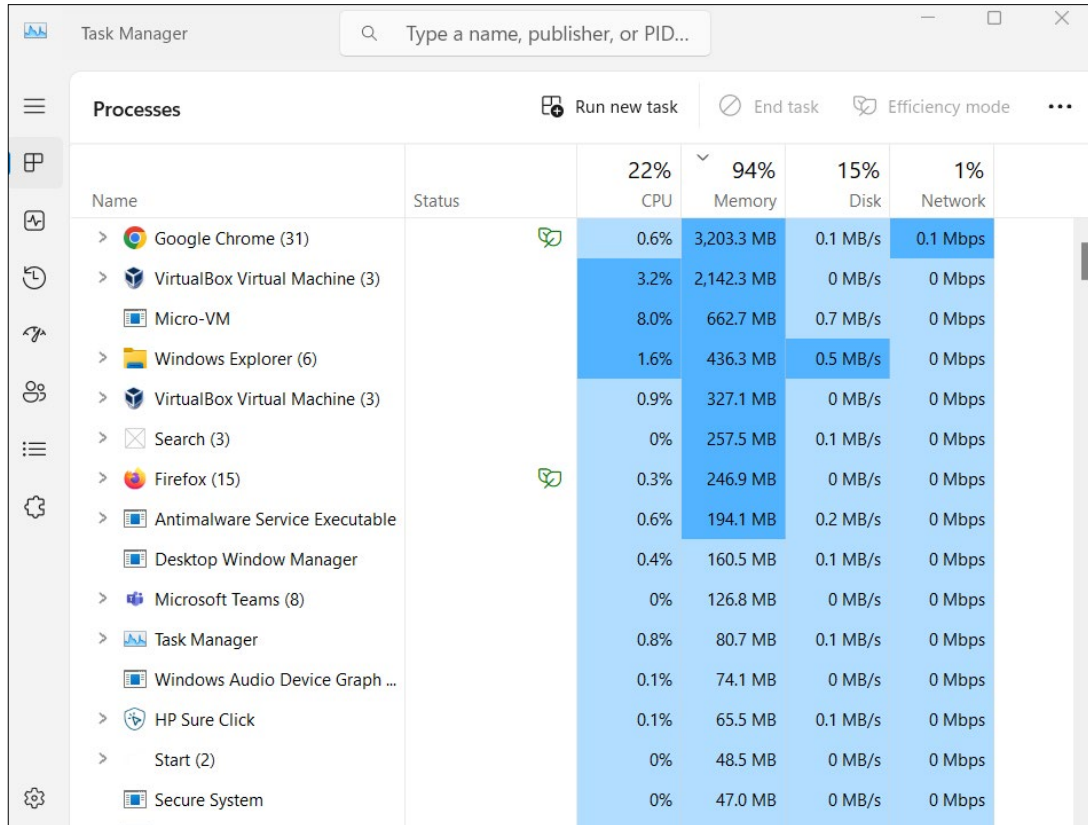
Para **evitar que el ataque se propague** a otros equipos, si el ordenador infectado está conectado a una red, se recomienda desconectarlo de inmediato. Además, sería importante bloquear todas las cuentas de usuario, excepto la del administrador, para impedir la ejecución de programas no autorizados que puedan interferir en las tareas de recuperación y gestión del sistema. Estas medidas nos ayudarán a proteger los archivos de datos y los programas, evitando que el ataque nos cause mayores problemas.

4

El paso siguiente es intentar detectar **qué vulnerabilidad** utiliza el ataque para sabotear el ordenador. La manera más eficiente de saber qué está pasando es mirar qué programas se están ejecutando. Pero, primero, se tienen que cerrar todos los programas que estaban en uso.

5

A continuación, analizaremos el **consumo de memoria y procesador** de cada programa y servicio que permanezca en ejecución. Para ello, si el sistema operativo es Windows, se puede utilizar el *Administrador de tareas*, como se muestra en la Figura 1. En el caso de sistemas Linux (Figura 2), se puede emplear el *Monitor del sistema* para llevar a cabo la misma operación.



Task Manager

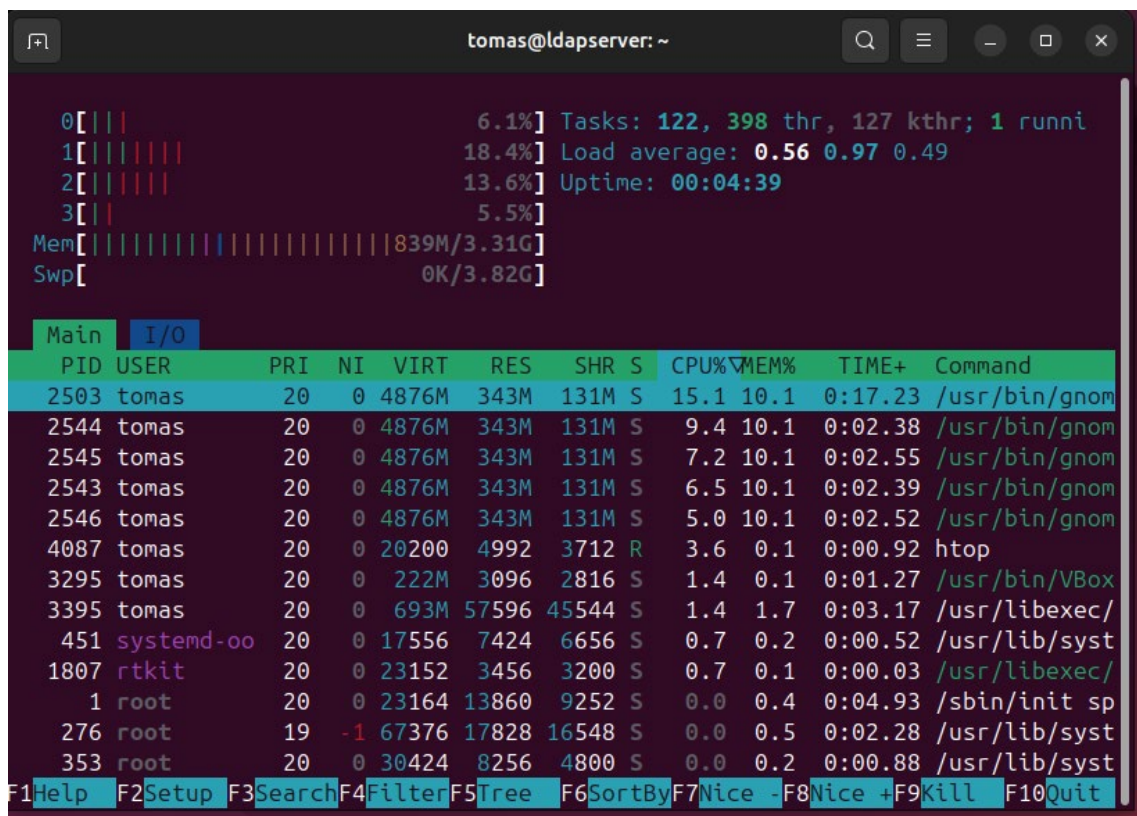
Search: Type a name, publisher, or PID...

Processes

Run new task | End task | Efficiency mode

Name	Status	CPU	Memory	Disk	Network
> Google Chrome (31)		0.6%	3,203.3 MB	0.1 MB/s	0.1 Mbps
> VirtualBox Virtual Machine (3)		3.2%	2,142.3 MB	0 MB/s	0 Mbps
Micro-VM		8.0%	662.7 MB	0.7 MB/s	0 Mbps
> Windows Explorer (6)		1.6%	436.3 MB	0.5 MB/s	0 Mbps
> VirtualBox Virtual Machine (3)		0.9%	327.1 MB	0 MB/s	0 Mbps
> Search (3)		0%	257.5 MB	0.1 MB/s	0 Mbps
> Firefox (15)		0.3%	246.9 MB	0 MB/s	0 Mbps
> Antimalware Service Executable		0.6%	194.1 MB	0.2 MB/s	0 Mbps
Desktop Window Manager		0.4%	160.5 MB	0.1 MB/s	0 Mbps
> Microsoft Teams (8)		0%	126.8 MB	0 MB/s	0 Mbps
> Task Manager		0.8%	80.7 MB	0.1 MB/s	0 Mbps
Windows Audio Device Graph ...		0.1%	74.1 MB	0 MB/s	0 Mbps
> HP Sure Click		0.1%	65.5 MB	0.1 MB/s	0 Mbps
> Start (2)		0%	48.5 MB	0 MB/s	0 Mbps
Secure System		0%	47.0 MB	0 MB/s	0 Mbps

Fig. 1. Administrador de tareas.



tomas@ldapserver: ~

0[||||| 6.1%] Tasks: 122, 398 thr, 127 kthr; 1 runni

1[||||||| 18.4%] Load average: 0.56 0.97 0.49

2[||||||| 13.6%] Uptime: 00:04:39

3[||||| 5.5%]

Mem[||||||||| 839M/3.31G]

Swp[||||| 0K/3.82G]

Main I/O

PID	USER	PRI	NI	VIRT	RES	SHR	S	CPU%	MEM%	TIME+	Command
2503	tomas	20	0	4876M	343M	131M	S	15.1	10.1	0:17.23	/usr/bin/gnom
2544	tomas	20	0	4876M	343M	131M	S	9.4	10.1	0:02.38	/usr/bin/gnom
2545	tomas	20	0	4876M	343M	131M	S	7.2	10.1	0:02.55	/usr/bin/gnom
2543	tomas	20	0	4876M	343M	131M	S	6.5	10.1	0:02.39	/usr/bin/gnom
2546	tomas	20	0	4876M	343M	131M	S	5.0	10.1	0:02.52	/usr/bin/gnom
4087	tomas	20	0	20200	4992	3712	R	3.6	0.1	0:00.92	htop
3295	tomas	20	0	222M	3096	2816	S	1.4	0.1	0:01.27	/usr/bin/VBox
3395	tomas	20	0	693M	57596	45544	S	1.4	1.7	0:03.17	/usr/libexec/
451	systemd-oo	20	0	17556	7424	6656	S	0.7	0.2	0:00.52	/usr/lib/syst
1807	rtkit	20	0	23152	3456	3200	S	0.7	0.1	0:00.03	/usr/libexec/
1	root	20	0	23164	13860	9252	S	0.0	0.4	0:04.93	/sbin/init sp
276	root	19	-1	67376	17828	16548	S	0.0	0.5	0:02.28	/usr/lib/syst
353	root	20	0	30424	8256	4800	S	0.0	0.2	0:00.88	/usr/lib/syst

F1 Help F2 Setup F3 Search F4 Filter F5 Tree F6 SortBy F7 Nice - F8 Nice + F9 Kill F10 Quit

Fig. 2. htop Ubuntu.

De este modo, será posible **identificar la aplicación que está ralentizando el sistema y detenerla**. Sería recomendable tomar nota del programa y del archivo ejecutable asociado, ya que esto permitirá verificar posteriormente si dicha aplicación debía estar instalada y si es necesario eliminarla del sistema. Los servicios pueden proporcionar más pistas, tal como se puede ver en la Figura 3.

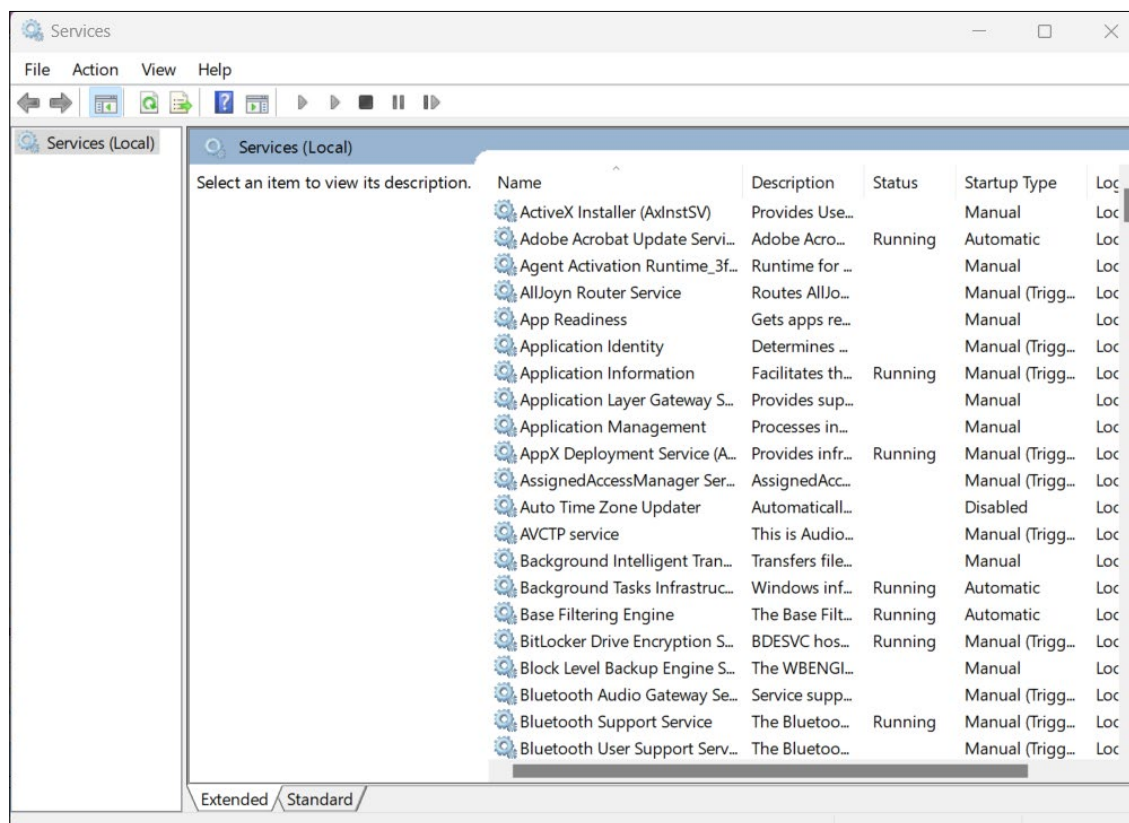


Fig. 3. Servicios.

Cuando revises los programas que se encuentran en ejecución, podrás ver si hay algún servicio que **gaste más recursos de lo normal**. Es importante comprobar si aparecen archivos nuevos con nombres y extensiones extrañas, cuyo contenido se debería ver con algún editor de texto, como el Bloc de notas en Windows (Notepad o Notepad++) o el editor Vi/Nano en Linux. De esta manera, quizás se pueda saber qué tipo de ataque se está sufriendo.

Podría ser que aparecieran aplicaciones que no has instalado. En este caso, se tendrían que desinstalar. También es necesario desinstalar las aplicaciones que tengan nombres raros. Siempre es mejor desinstalar un programa y volverlo a instalar que tener uno instalado que perjudique al equipo.

A continuación, se intentará **solucionar la vulnerabilidad** que está utilizando el atacante. No siempre es posible identificar la vulnerabilidad concreta que explota el ataque, pero sí se podrá obtener una idea aproximada de su origen.

Lo más recomendable es **buscar una actualización de seguridad que corrija la falla** en la aplicación o en el propio sistema operativo. Es importante utilizar Windows update o apt-get update/upgrade en Linux. Después de actualizar el equipo, es necesario eliminar los servicios activos y desinstalar las aplicaciones sospechosas. También sería conveniente realizar un análisis exhaustivo del equipo con un antivirus actualizado para eliminar posibles amenazas. Además, se recomienda instalar un programa antispymware para eliminar software espía (spyware), como el que recopila direcciones de email o muestra publicidad no deseada, ya que suelen ralentizar el sistema.

El último paso consiste en **reparar los daños** que haya podido causar el ataque. Para recuperar los datos perdidos o dañados, bastará con restaurar el último backup disponible. Esto solo es posible si se ha llevado a cabo una buena planificación dentro del plan de contingencia correspondiente.

Seguramente será necesario reinstalar algunos programas que hayan resultado afectados. Una vez hecho esto, es recomendable **cambiar las contraseñas** de los usuarios del equipo. También es aconsejable replantear los permisos de los usuarios. Para finalizar, se debe restaurar la conexión de red, desbloquear las cuentas de usuario y reiniciar los servicios que se habían detenido. Lo más fácil es reiniciar el equipo para que todos los servicios, una vez desbloqueados, se activen correctamente.

IMPORTANTE

Es fundamental intentar **localizar e identificar al intruso**. Para ello, se deben analizar las pistas que haya dejado durante el ataque, ya que el sistema guarda registros de los accesos realizados. También se pueden revisar las aplicaciones activas para buscar incidencias en los archivos del sistema y en los datos de red.

Con esta información, podremos determinar si el atacante es un **empleado de la empresa o si el ataque proviene de una fuente externa**. Además, se podrá identificar si ha utilizado métodos de acceso no autorizado a la red corporativa. No obstante, el incidente también podría haber sido causado por el descuido de un usuario dentro de la empresa o por una vulnerabilidad en alguna aplicación del sistema. La identificación del intruso permitirá corregir el problema y tomar medidas preventivas para evitar ataques futuros.

Con el crecimiento del trabajo remoto y el almacenamiento en la nube, es cada vez más necesario aplicar medidas de seguridad para evitar accesos no autorizados y filtraciones de datos.

D. Seguridad en entornos de nube y dispositivos móviles

Seguridad en la nube

- Autenticación multifactor (MFA): habilitar la verificación en dos pasos para proteger el acceso a cuentas en la nube.
- Cifrado de datos: asegurar que los archivos guardados en la nube estén cifrados.
- Accesos restringidos: aplicar políticas de control de acceso para limitar quién puede ver o modificar la información.
- Monitorización y auditoría: usar herramientas que detecten accesos sospechosos y bloqueen actividades no autorizadas.

Seguridad en dispositivos móviles

- Evitar redes wifi públicas sin protección: utilizar VPN para proteger el tráfico de datos.
- Configurar el bloqueo de dispositivos con pin, huella digital o reconocimiento facial.
- Actualizar las aplicaciones y el sistema operativo para corregir vulnerabilidades.
- Instalar solo apps de fuentes confiables, evitando APK de terceros o tiendas no oficiales.
- Habilitar el borrado remoto en caso de robo o pérdida del dispositivo.

1.2. Implementación de mecanismos para verificar el origen y la autenticidad de las aplicaciones

Normalmente, los fabricantes de software, en especial en el caso de los sistemas operativos, cuentan con **mecanismos de distribución de actualizaciones de seguridad** para sus productos. En este apartado, vamos a ver cuáles son las medidas de seguridad adoptadas con este propósito, prestando especial atención a la verificación de la autenticidad y la integridad del paquete que se va a instalar.

Las formas más conocidas de verificación son las siguientes:

- » **Firma digital del archivo:** es el método más fiable y permite verificar la actualización sin necesidad de conexión a la red. Cuando intentamos instalar un archivo descargado de Internet, el sistema busca información sobre el fabricante y la firma electrónica con el certificado correspondiente y su origen. Además, verifica su autenticidad y su validez. Si encuentra un certificado válido, nos avisa y solicita confirmación para proceder con la instalación. En caso contrario, muestra un mensaje por pantalla en el que se ofrece la opción de continuar con la instalación sin el certificado.
- » **Windows Genuine Advantage (WGA):** se trata de un sistema antipiratería implementado por Microsoft para validar las licencias de sistemas operativos antiguos como **Windows XP** y **Windows Vista**. A partir de **Windows 7**, WGA fue reemplazado por **Windows Activation Technologies (WAT)**, que cumplía funciones similares de validación de licencias. En las versiones más nuevas de Windows, como **Windows 10** y **Windows 11**, Microsoft ha integrado mecanismos

de activación y validación directamente en el sistema operativo, eliminando la necesidad de herramientas separadas como WGA.

- » **Activación digital:** actualmente, con la **activación digital**, que se asocia a la cuenta de Microsoft, se simplifica mucho el proceso de activación. El hardware del dispositivo genera una **huella digital** única que queda registrada en los servidores de Microsoft. Esto permite una activación automática y sin complicaciones al reinstalar el sistema operativo en el mismo equipo o al migrar a un nuevo dispositivo.
- » **OGA (Office Genuine Advantage):** se trata de un programa de Microsoft diseñado de manera similar a WGA. Su propósito era exigir a los usuarios de Microsoft Office la validación de su copia del software para poder descargar actualizaciones no críticas, así como otros elementos adicionales como complementos y herramientas opcionales.
- » **Activación de producto integrada:** al igual que con Windows, la validación de licencias en las versiones modernas de Microsoft Office se ha integrado directamente en el software. Microsoft ha pasado a un modelo de suscripción con **Microsoft 365**, en el que la validación de licencias se gestiona a través de cuentas de usuario y servicios en la nube.
- » **Microsoft 365:** el modelo de suscripción de **Microsoft 365** ha cambiado fundamentalmente la forma en que se distribuye y valida Office. En lugar de validar copias de software instaladas localmente, Microsoft valida las suscripciones de los usuarios en la nube. Esto no solo garantiza la autenticidad del software, sino que también permite a los usuarios acceder a actualizaciones constantes, funciones adicionales y almacenamiento en la nube.
- » **Actualizaciones automáticas desde fuentes oficiales:** descargando aplicaciones y actualizaciones directamente desde tiendas oficiales (Microsoft Store, Google Play, App Store) o sitios web certificados para evitar archivos comprometidos.
- » **Política de control de acceso y listas blancas:** permitir solo la instalación de aplicaciones aprobadas y verificadas, evitando la ejecución de software desconocido o no autorizado.
- » **Software de gestión de identidad y acceso (IAM):** herramientas como Azure AD, Okta o Google Workspace permiten controlar quién tiene acceso a las aplicaciones y verificar su autenticidad.
- » **Escaneo de seguridad con herramientas antimalware:** antes de la instalación, se pueden analizar las aplicaciones con soluciones de seguridad como Windows Defender, Avast o Malwarebytes para detectar posibles amenazas.
- » **Gestores de paquetes seguros:** en sistemas operativos como Linux o macOS, se utilizan gestores de paquetes confiables como APT, YUM, Homebrew, que verifican la autenticidad de los paquetes antes de su instalación.

- » **Uso de protocolos seguros (HTTPS, SFTP):** nos tenemos que asegurar de que la descarga de aplicaciones se realice a través de conexiones cifradas para evitar la interceptación de archivos maliciosos.

A. Aplicación del algoritmo MD5 o funciones HASH

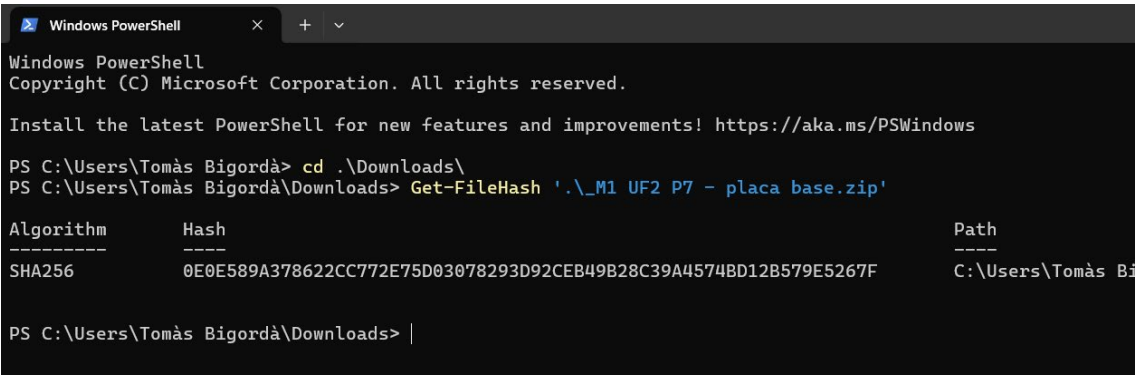
Las certificaciones tradicionales en software libre no son comunes, dada la total apertura del código, que puede modificarse libremente. Pero, con esta libertad, existe el peligro de que alguien introduzca alteraciones en una parte del código y redistribuya versiones amañadas que pueden contener elementos maliciosos.

Para reducir estos riesgos, se emplean mecanismos que verifican la integridad de los paquetes de software. Uno de los métodos más utilizados es el uso de **funciones hash criptográficas**, como el algoritmo MD5 u otros más modernos, que generan un valor único (hash) basado en el contenido del archivo.

Los desarrolladores calculan este hash y lo publican junto con el archivo de descarga. De este modo, usuarios como nosotros podemos calcular el hash del archivo descargado y compararlo con el proporcionado por los desarrolladores; si coinciden, se asegura que el archivo no ha sido alterado.

No obstante, es importante destacar que MD5 ya no se considera seguro para fines criptográficos, debido a ciertas vulnerabilidades que permiten la generación de colisiones, es decir, diferentes archivos que producen el mismo hash. Por lo tanto, se recomienda utilizar algoritmos más seguros, como los **estándares SHA-2 o SHA-3**, que ofrecen una mayor resistencia a los ataques y garantizan la integridad del fichero.

Existen muchas aplicaciones que calculan el hash, operación necesaria para validar la integridad de los archivos descargados. Aunque no es necesario instalar ninguna aplicación, lo podemos calcular fácilmente desde el powershell de Windows.



```
Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.

Install the latest PowerShell for new features and improvements! https://aka.ms/PSWindows

PS C:\Users\Tomàs Bigordà> cd .\Downloads\
PS C:\Users\Tomàs Bigordà\Downloads> Get-FileHash '.\_M1 UF2 P7 - placa base.zip'

Algorithm      Hash                                                    Path
-----
SHA256         0E0E589A378622CC772E75D03078293D92CEB49B28C39A4574BD12B579E5267F  C:\Users\Tomàs Bi
PS C:\Users\Tomàs Bigordà\Downloads> |
```

Fig. 4. Hash.



WEB

Cómo verificar el hash de archivos descargados de Internet en Windows 10:

<https://www.youtube.com/watch?v=BZU-bKRSDHY>

La autenticidad y la integración son importantes porque muchos de los servidores donde se aloja el software son muy vulnerables. Además, podrían ser víctimas de ataques del tipo **DNS spoofing**, por medio de los cuales el atacante redirige al usuario a un servidor incorrecto, diferente del que se ha introducido en la URL.

1.3. Implementación de métodos para la recuperación de datos

En caso de pérdida de datos en una pyme, se puede generar una situación complicada, ya que esto podría implicar la imposibilidad de continuar con la actividad diaria, hasta el punto de provocar un cierre temporal de la empresa, e incluso, en algunos casos, un cierre definitivo.

Para evitar estas situaciones difíciles, es fundamental contar con diferentes técnicas de recuperación de datos. Como se ha comentado en unidades anteriores, la mejor es disponer de una buena política preventiva como las **copias de seguridad programadas**. Si se cuenta con copias de seguridad, la recuperación de los datos será más rápida y efectiva.

A. Backups

La pérdida de datos se puede producir por varios motivos. Es posible que los nombres de los archivos se cambien y, después, sea difícil reencontrarlos. También puede ser que, a raíz de un accidente, se sobrescriban, se eliminen o que se pierdan porque se ha estropeado algún disco o por un simple robo del equipo.

Para recuperar los datos, lo más efectivo es contar con una política de copias de seguridad o de creación de imágenes del disco duro. Estos backups se pueden realizar **en otro disco duro nuestro o en la nube**. Otro método funcional para evitar pérdidas de datos en caso de corrupción de los discos es el **sistema RAID**.

Podemos hacer las copias de seguridad desde el mismo sistema operativo o utilizar aplicaciones específicas para ello, tanto open source como propietarias. Estas aplicaciones nos permiten realizar backups de manera automatizada o manual y recuperar posteriormente los datos que se hayan guardado.

B. Recuperación de datos sin respaldo



¿SABÍAS QUE...?

Los datos guardados en el ordenador realmente **no desaparecen** hasta que la unidad se quema o se destruye completamente.

Para entender en profundidad cómo se **recuperan** los archivos desaparecidos, tendríamos que estudiar cómo se almacena la información en el disco de forma detallada, pero esto excede a los propósitos de esta unidad. Para simplificarlo, tenemos que saber que las plataformas Windows, Mac y Linux formatean los discos duros y guardan la información de maneras diferentes.



WEB

Cómo se guardan los archivos en un disco duro:

<https://recuperaciondedatos.com.mx/como-se-guardan-los-archivos-en-un-disco-duro/>

Aun así, independientemente de cómo se guardan los datos en el disco duro, es decir, de qué sistema de archivos estemos utilizando, debes saber que, **cuando se borra un archivo, el sistema operativo realmente no lo elimina del todo**. En vez de borrarlo, traslada la entrada del directorio del archivo y la información sobre la ubicación original a una carpeta oculta especial, que representa la *Papelera de reciclaje*. Por lo tanto, los clústeres de datos del disco duro no se eliminan, ni siquiera se mueven de lugar, sino que solo se modifica la ubicación de la entrada del directorio.

En todos los sistemas operativos, **el nombre del archivo, la entrada de índice o el directorio** se modifican para indicar que el usuario no tendría que poder ver el archivo y que el espacio que ocupaba está disponible y se puede reutilizar. Cuando llegue el momento, la unidad sobrescribirá con información nueva el espacio disponible.

Eso significa que existe la posibilidad de recuperar la información que todavía no se ha sobrescrito. Si el archivo todavía está en la papelera de reciclaje, basta con pulsar el archivo con el botón derecho y seleccionar *Recuperar* o arrastrarlo hasta el lugar donde lo queremos colocar.

Aun en el caso de que **un archivo ya se haya eliminado de la papelera de reciclaje** y esta papelera no tuviera incorporada ninguna aplicación para ofrecer más protección, el archivo todavía no ha desaparecido del disco duro y hay herramientas para localizar y, después, volver a juntar todos los clústeres del disco duro que guardaban los datos del archivo.

Es necesario recordar que **solo podrás reconstruir los archivos que no hayan sido sobrescritos**, de forma que es necesario no efectuar operaciones de escritura mientras intentas recuperar un archivo eliminado. Si previamente no se ha instalado ninguna herramienta de recuperación, no es un buen momento para hacerlo, puesto que el archivo que intentas recuperar se podría sobrescribir. De este modo, tendrás que buscar alternativas, como compartir el disco duro con otra máquina e intentar recuperarlo desde esta otra.

En el mercado actual, existen **diversas soluciones** de software especializadas en la recuperación de datos, cada una con unas características y una compatibilidad específicas según las necesidades del usuario. A continuación, puedes ver una tabla con una selección de algunos de los programas más populares.

SOFTWARE DE RECUPERACIÓN	DESARROLLADOR	SISTEMAS OPERATIVOS SOPORTADOS
Wondershare Recoverit	Wondershare	Windows, macOS
Recuva	Piriform	Windows
Stellar Data Recovery	Stellar Information Technology	Windows, macOS
Disk Drill	CleverFiles	Windows, macOS
R-Studio	R-Tools Technology Inc.	Windows, macOS, Linux
PhotoRec	CGSecurity	Windows, macOS, Linux
Wise Data Recovery	WiseCleaner	Windows
GetDataBack	Runtime Software	Windows
Ontrack EasyRecovery	Kroll Ontrack	Windows, macOS
MiniTool Power Data Recovery	MiniTool Solution Ltd.	Windows

Tabla 1. Algunos de los programas más populares de recuperación de archivos.

Otra forma de intentar recuperar archivos puede ser a través de **comandos**. En Windows se puede intentar recuperar archivos mediante el comando **chkdsk** o utilizando **attrib** para mostrar archivos ocultos.

```
chkdsk X: /f
```

(Reemplaza X con la letra de la unidad afectada).

En macOS y Linux se puede usar el comando **fsck** para comprobar y reparar unidades dañadas.

IMPORTANTE

En caso de que no podamos recuperar los archivos de ninguna de las maneras comentadas y estos sean críticos, es recomendable acudir a un **servicio profesional de recuperación de datos**. Estos servicios utilizan herramientas avanzadas tanto de software como de hardware para recuperar información de discos dañados o formateados.

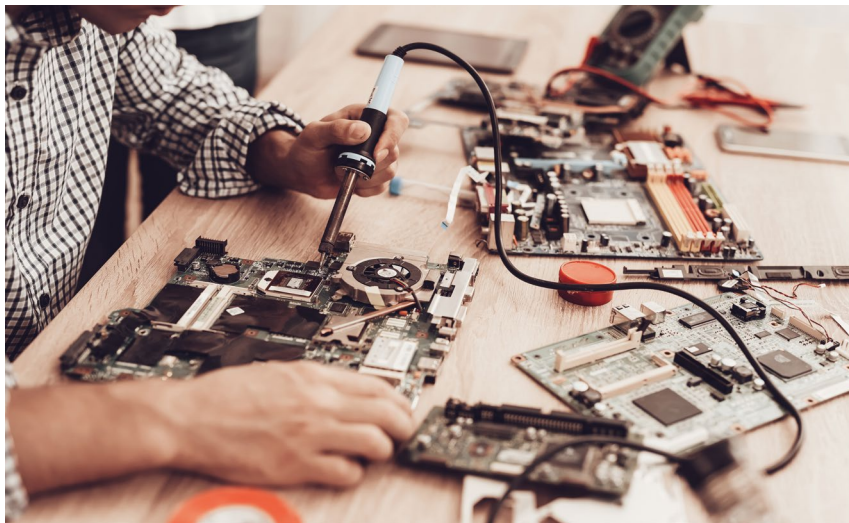


Fig. 5. Técnico recuperando datos.

1.4. Métodos de identificación: firma electrónica y certificado digital

Internet ha contribuido de manera significativa en la globalización de nuestras vidas, hecho que ha provocado que se convierta en una herramienta totalmente necesaria e imprescindible para la mayoría de las empresas.

Sin embargo, la **conexión a Internet lleva implícita un riesgo** de seguridad para el sistema informático de la empresa. Esto ha obligado a los administradores de red a establecer políticas de seguridad que permitan crear conexiones seguras y garantizar el envío y la recepción de información cifrada, así como a implementar filtros de acceso y control de datos, entre otras medidas de protección.

IMPORTANTE

En este sentido, uno de los mayores problemas es la **privacidad de los datos**. Hasta ahora, no había ninguna protección real que garantizara que los mensajes que se envían o se reciben no fueran interceptados, leídos o incluso alterados por algún desconocido, puesto que realmente no hay nadie que dirija o controle la red de Internet. Este hecho provoca que se planteen posibles preguntas; por ejemplo: ¿cómo saber si una persona tiene, efectivamente, una cuenta válida? o ¿cómo saber si se puede confiar en una tienda online que no se ha visitado nunca? Para que la privacidad y la seguridad en Internet tengan la relevancia que les corresponde, cada entidad necesita tener una manera de verificar la identidad de las otras, para así y poder establecer cierto nivel de confianza. El certificado digital y la firma electrónica son algunas de las herramientas que permiten establecer conexiones seguras entre las personas y las administraciones. Además, ofrecen la posibilidad de hacer transacciones comerciales.

A. Certificado digital

Los certificados digitales son clave en la seguridad de las transacciones electrónicas de hoy en día, ya que nos proporcionan un método seguro y fiable para mantener comunicaciones digitales confiables. Esta confianza se basa en la intervención de **autoridades de certificación (CA)**, que verifican la identidad de los solicitantes y emiten los certificados digitales correspondientes.

» **Proceso de obtención de un certificado digital:** para obtener un certificado digital, el usuario tiene que acudir a una **autoridad certificadora**, identificarse de forma correcta y, una vez verificada su identidad, recibir el certificado digital. A continuación, al enviar mensajes que requieran autenticación, basta con autenticar el certificado digital. De este modo, el receptor puede verificar correctamente la identidad del remitente, lo que resulta esencial en comunicaciones con empresas, administraciones públicas y otros entornos de confianza. Estos certificados utilizan cifrados criptográficos que garantizan **la confidencialidad, la integridad y la autenticidad** de la información transmitida, aspectos esenciales tanto para los usuarios individuales como para las empresas.

» **Cifrado y seguridad en la comunicación:** el proceso de cifrado consiste en transformar un mensaje en un código ilegible mediante el uso de una clave. Es lo que conocemos como **encriptación**, proceso que transforma la información para que solo el destinatario autorizado pueda entenderla. Actualmente, se pueden clasificar los certificados digitales en diferentes categorías:

Certificados de servidor (SSL/TLS)	Garantizan la seguridad de las conexiones web mediante el cifrado seguro de datos en tránsito.
Certificados Microsoft Server Gated Cryptography (SGC)	Son una extensión del protocolo SSL que proporciona Microsoft para entornos específicos.
Certificados de canal seguro	Protegen las comunicaciones en canales específicos, como VPN o túneles de comunicación.
Certificados de correo electrónico (S/MIME)	Permiten firmar y cifrar correos electrónicos para garantizar su autenticidad y confidencialidad.
Certificados de autenticación de sitios web	Verifican la legitimidad de las páginas web, protegiéndolas contra la suplantación de identidad (phishing).
Certificados de sello de tiempo (timestamp)	Garantizan la validez de los documentos digitales mediante un sello de fecha y hora confiable.

» **Cifrado de clave simétrica vs. clave asimétrica (clave pública y privada):** los cifrados de clave **secreta (clave simétrica)** utilizan una clave tanto para el proceso de cifrado como para el proceso de descifrado. En este tipo de sistemas, cada usuario debe tener acceso a la misma clave privada. Las claves privadas pueden compartirse a través de un canal de comunicación seguro previamente establecido, como un servicio de mensajería privado o una línea segura, pero esto, al final, resulta poco práctico hoy en día.

Para solucionar las limitaciones de un canal seguro para intercambiar la clave secreta, se desarrolló una solución conocida como **cifrado de clave pública (asimétrica)**. Este sistema, introducido en la década de 1970, utiliza dos claves diferentes pero complementarias.

B. Firma electrónica

La firma electrónica es, como seguramente habrás adivinado, otro componente crítico en un certificado digital. Junto con los datos del usuario y la clave pública, un certificado digital se utiliza para garantizar al receptor la **identidad del autor** de un mensaje. En otras palabras, proporciona mecanismos para que el receptor pueda verificar la autenticidad del documento, impide que el autor pueda repudiar su creación y garantiza que el contenido del mensaje no pueda ser alterado sin ser detectado.

Por ejemplo, cuando un usuario A envía un mensaje a un usuario B, puede cifrarlo junto con su certificado digital. Opcionalmente, el mensaje puede ser protegido con la clave pública del usuario B, lo que se conoce como **firma digital**. Este proceso garantiza que nadie pueda modificar el contenido del mensaje sin invalidar el certificado del emisor, lo que protege la integridad y la confidencialidad de la información que se transmite.

Estas firmas consisten en bloques de datos codificados mediante una clave privada y que pueden ser verificados con su clave pública. Su función principal es garantizar la autenticidad del mensaje o la validez de una clave pública, proporcionando un alto nivel de seguridad en las comunicaciones digitales.

En España, la **Ley 6/2020, de 11 de noviembre**, establece el marco legal actual para el uso de la firma electrónica, sustituyendo a la anterior **Ley 59/2003**. Esta norma define tres tipos principales de firma electrónica, para cumplir con el Reglamento eIDAS de la Unión Europea:

Firma digital simple	Firma digital avanzada	Firma digital cualificada
Es el tipo más básico de firma digital y no está protegido por ningún método de encriptación. Es el equivalente electrónico de una firma húmeda escaneada o de una firma de correo electrónico.	Está vinculada a firmantes específicos y proporciona un mayor nivel de seguridad que una firma digital simple. Utiliza estándares de infraestructura de clave pública (PKI) para proporcionar un alto nivel de seguridad y aceptación universal.	Es el tipo más seguro de firma digital y requiere un nivel más riguroso de garantía de identidad a través de certificados digitales. Es legalmente vinculante en muchos países y tiene el mismo valor que las firmas manuscritas tradicionales.

El Reglamento **eIDAS, (UE) N.º 910/2014**, establece un marco normativo común en la UE para la firma electrónica, garantizando su reconocimiento mutuo entre los Estados miembros y proporcionando un marco de confianza para transacciones electrónicas seguras.

Con el uso masivo de Internet, las firmas digitales se han convertido en indispensables para los trámites en los que se requiere una mínima seguridad jurídica y protección de datos.

1.5. Emisión de identificaciones electrónicas y aplicación de la firma digital

Los certificados digitales y las firmas electrónicas permiten realizar **transacciones seguras a través de Internet**, además de proporcionar un medio fiable para la identificación de personas. Un ejemplo útil podría el de la Agencia Tributaria, donde, una vez autenticados en el sitio, se pueden realizar diversas gestiones en línea que no serían posibles sin esta identificación.

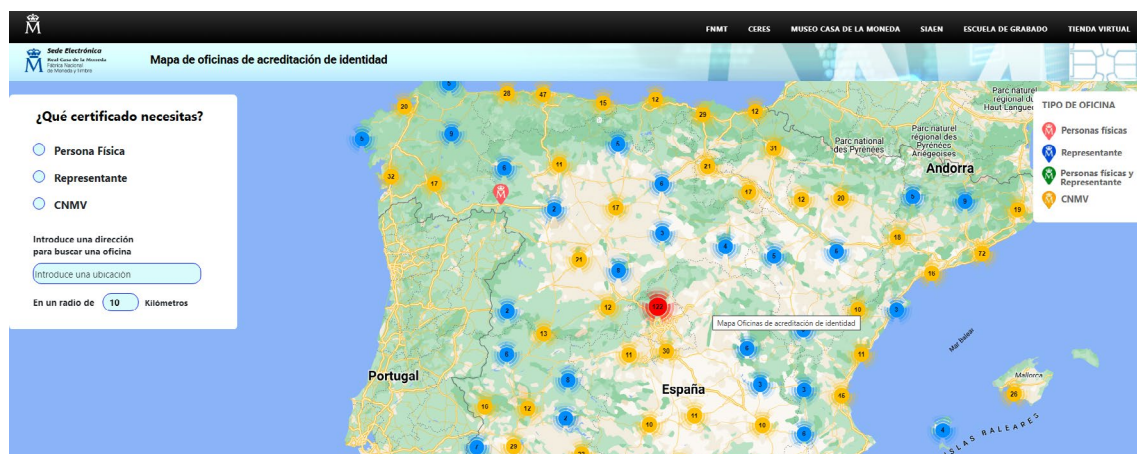
The screenshot shows the 'Identificate con' (Identify with) section of the Agencia Tributaria website. It offers two options: 'Cl@ve Móvil (anteriormente Cl@ve PIN)' and 'Certificado o DNI electrónico'. Below these options is a link: '¿Tienes dudas? visita la ayuda de identificación electrónica'. To the right, there is a section titled '¿Qué es un certificado electrónico?' which explains that an electronic certificate is a digital signature installed in a browser to guarantee identity on the internet, allowing transactions from a computer, mobile device, or tablet. It also mentions that the electronic DNI allows identification for internet transactions.

Esto activa nuestro certificado digital. Previamente, cada usuario ha acudido personalmente a una entidad emisora de certificaciones electrónicas para verificar su identidad.

En nuestro país, existen centenares de organismos autorizados para la emisión de certificados digitales repartidos por toda la geografía nacional.

WEB

Puedes buscar la mejor opción para ti en: <https://mapaoficinascert.appspot.com/>



A. Proceso de obtención de un certificado digital

Para obtener un certificado digital, el usuario se tiene que presentar en un centro emisor oficial con la documentación requerida. Una vez verificada su identidad, se le proporcionará un software específico que deberá instalar en sus dispositivos informáticos.

Por ejemplo, así puedes obtener el certificado de la Fábrica Nacional de Moneda y Timbre: <https://sede.agenciatributaria.gob.es/Sede/ayuda/consultas-informaticas/firma-digital-sistema-clave-pin-tecnica/informacion-pasos-obtencion-certificado-electronico.html>

Una vez que tengamos el certificado, podemos **firmar digitalmente documentos e emails**, asegurando así su autenticidad y su integridad. Además, podemos realizar la mayoría de los trámites administrativos, de modo que evitamos desplazamientos y citas previas interminables.



WEB

En el siguiente link, tienes un listado de la multitud de trámites que podrás realizar:

<https://www.cert.fnmt.es/que-es-ceres/donde-puedo-usar-mi-certificado>

Para **garantizar la validez y la efectividad de una firma electrónica**, existen diversas herramientas online, como **VALIDe**, proporcionada por la propia Administración pública. Con VALIDe se podrá consultar la validez de un documento firmado electrónicamente, realizar una firma electrónica, comprobar la vigencia de un certificado digital emitido por cualquier entidad de servicio de certificación reconocida, etc.

The screenshot shows the VALIDe website interface. At the top, there are logos for 'gob.es' and 'VALIDe', along with navigation links: 'Bienvenido', 'Benvingut', 'Ongi etorri', 'Benvido', and 'Welcome'. There is also a 'Contactar' button and a logo for the 'GOBIERNO DE ESPAÑA'.

The main content area is titled 'Validar Firma' and includes the text: 'Puedes comprobar la validez de una firma digital utilizando para ello la plataforma @firma.' Below this, there are two steps:

1. Selecciona la firma a validar. This step includes a 'Choose file' button and the text 'No file chosen'. Below this, it says 'Tamaño máximo de fichero admitido (8 MBs)'.
2. Introduce el código de seguridad. This step shows a sample signature 'A6fb6c' and a text input field labeled 'Escribe el código de seguridad'. Below the input field is a red 'Validar' button.

At the bottom, there is a note: 'Nota: Las firmas soportadas por el sistema son aquellas que han sido realizadas con los certificados admitidos por el Ministerio de Industria, Energía y Turismo. Se pueden consultar los certificados admitidos revisando el documento Certificados admitidos por la plataforma @firma. Si tu firma no se valida correctamente, porque se indica certificado no soportado, pero tu certificado sí se encuentra entre los recogidos en la Página del Ministerio de Industria te rogamos te pongas en contacto con el servicio de soporte.'

The footer contains the European Union flag logo, the text 'UNIÓN EUROPEA', 'PROYECTO COFINANCIADO POR EL FONDOS EUROPEOS DE DESARROLLO REGIONAL', and 'FEDER'. It also includes logos for 'WS2', 'WS3', 'WS4', 'WS5', 'WS6', 'WS7', 'WS8', 'WS9', 'WS10', 'WS11', 'WS12', 'WS13', 'WS14', 'WS15', 'WS16', 'WS17', 'WS18', 'WS19', 'WS20', 'WS21', 'WS22', 'WS23', 'WS24', 'WS25', 'WS26', 'WS27', 'WS28', 'WS29', 'WS30', 'WS31', 'WS32', 'WS33', 'WS34', 'WS35', 'WS36', 'WS37', 'WS38', 'WS39', 'WS40', 'WS41', 'WS42', 'WS43', 'WS44', 'WS45', 'WS46', 'WS47', 'WS48', 'WS49', 'WS50', 'WS51', 'WS52', 'WS53', 'WS54', 'WS55', 'WS56', 'WS57', 'WS58', 'WS59', 'WS60', 'WS61', 'WS62', 'WS63', 'WS64', 'WS65', 'WS66', 'WS67', 'WS68', 'WS69', 'WS70', 'WS71', 'WS72', 'WS73', 'WS74', 'WS75', 'WS76', 'WS77', 'WS78', 'WS79', 'WS80', 'WS81', 'WS82', 'WS83', 'WS84', 'WS85', 'WS86', 'WS87', 'WS88', 'WS89', 'WS90', 'WS91', 'WS92', 'WS93', 'WS94', 'WS95', 'WS96', 'WS97', 'WS98', 'WS99', 'WS100'. It also includes links for 'Accesibilidad', 'Mapa Web', 'Requisitos', and 'Condiciones de Uso'.

Fig. 6. Validar firma electrónica con VALIDe.

1 CASO PRÁCTICO



ELABORACIÓN DE UN PLAN DE CONTINGENCIA PARA UNA PYME DE COMERCIO ELECTRÓNICO

La empresa XShop, una pyme especializada en comercio electrónico y digital, ha identificado diversos riesgos de seguridad que podrían comprometer las operaciones de la empresa. Entre las amenazas detectadas, se encuentran ataques de ransomware, pérdida o corrupción de datos críticos, fallos en la infraestructura tecnológica y vulnerabilidades en sus tiendas online. Dado el impacto potencial que estos incidentes podrían tener en la disponibilidad del servicio, la reputación de la empresa y la confianza de los clientes, XShop ha decidido desarrollar un plan de contingencia integral. Este plan tendrá como objetivo garantizar la continuidad del negocio, minimizar las interrupciones y establecer procedimientos efectivos para la detección, la respuesta y la recuperación ante incidentes de seguridad. Recuerda que tu plan constará de cinco fases:

Fase 1: evaluación de riesgos

- » Identificación de amenazas.
- » Impacto de las amenazas.
- » Recursos afectados.

Fase 2: planificación del plan de contingencia

- » Objetivos.
- » Estrategias de mitigación.
- » Plan de respuesta ante incidentes.

Fase 3: pruebas de viabilidad

- » Simulación de ciberataques.
- » Evaluación de tiempos de recuperación (RTO/RPO).
- » Capacitación del personal.

Fase 4: ejecución del plan

- » Pasos iniciales tras detectar un ataque.
- » Restauración de sistemas.
- » Comunicación interna y externa.

Fase 5: recuperación y mejora continua

- » Evaluación posincidente.
- » Actualización del plan de contingencia.
- » Medidas adicionales

02 Señales de alerta y riesgos de seguridad

Si hablamos de seguridad activa, disponemos de una serie de herramientas, como los **IDS (Intrusion Detecting System, sistema de detección de intrusos)** o los **IPS (Intrusion Prevention System, sistema de prevención de intrusos)**, entre otras, que nos pueden avisar y lanzar una alarma si sufrimos una incidencia de seguridad, ya sea por la detección de un intruso en nuestro sistema informático o por el descubrimiento de cualquier tipo de malware.

Cuando se descubre que hay una incidencia de seguridad, hace falta actuar de forma rápida para solventar los efectos que pueda tener en la infraestructura informática. Esta actuación estará guiada por el plan de contingencia establecido. No obstante, si dicho plan no existe o no contempla la incidencia específica, será necesario seguir las instrucciones y la documentación técnica proporcionada por el software que haya generado la alerta.



¿SABÍAS QUE...?

Como hemos visto, entendemos por plan de contingencia el conjunto de actuaciones que hay que realizar en caso de haber sufrido una incidencia de seguridad. Estas actuaciones están destinadas a reducir los efectos y recuperar el sistema. En caso de no disponer de ningún plan de contingencia y que el software de seguridad no nos ofrezca instrucciones, siempre nos quedará la opción de buscar información en Internet. Piensa que **tenemos toda la información disponible** y que solo es necesario saber buscar, ya que hay infinidad de recursos sobre incidencias de seguridad y múltiples foros en los que podrás encontrar las acciones por realizar. Esto es así porque, simplemente, hay otras personas o empresas que sufrieron el mismo problema de seguridad. Los foros son espacios en Internet destinados a la comunicación. Puedes dejar un mensaje explicativo y otras personas responderán a tu demanda.

Para terminar, una vez detectada la incidencia de seguridad correspondiente y resuelta con las instrucciones pertinentes, hará falta **documentar la incidencia**. Si dispones de un plan de contingencia y esta incidencia no consta porque no estaba prevista o no se había producido antes, es necesario que se incluya para eventualidades futuras.

2.1. Identificación y solución de problemas

Nuestro objetivo es mantener un sistema informático al máximo nivel de seguridad, para lo cual hay que disponer de una serie de herramientas y, además, mantenerlas actualizadas. Algunas de las herramientas más comunes son los antivirus, los cortafuegos y las actualizaciones del sistema.

También hay otras que no son tan conocidas, pero que pueden ser útiles en caso de detectar una incidencia de seguridad en nuestro sistema informático. El hecho de tener instalados programas de detección o prevención de intrusos, como los IDS o los IPS y, más particularmente, los **NIDS (Network Intrusion Detection System, sistema de detección de intrusos en red)** y los **HIDS (Host-based Intrusion Detection System, sistema de detección de intrusos en una máquina)** nos permitirá detectar intrusiones no deseadas en el sistema.

Igualmente, mantener nuestro sistema actualizado, sobre todo en cuanto a lo relacionado con la seguridad, nos ahorrará muchos problemas. Buena parte de estas actualizaciones están destinadas a evitar la entrada de malware o intrusiones no deseadas, puesto que corrigen posibles vulnerabilidades descubiertas y explotadas por hackers. Si utilizas Windows, simplemente escribe «update» en la barra de búsqueda, y ya puedes acceder a las actualizaciones.

Lo recomendable es marcar la opción de **actualizaciones automáticas**.

En caso de utilizar un entorno Ubuntu en Linux, lo más rápido es hacerlo vía comandos. En primer lugar, utilizando el siguiente comando para obtener la lista más reciente de paquetes disponibles desde los repositorios:

```
sudo apt update
```

Después, para instalar las versiones más recientes de los paquetes disponibles, tenemos que usar:

```
sudo apt upgrade -y
```

A. Control de incidencias

Hay dos maneras principales de detectar una incidencia de seguridad:

- » La **primera** es recibir una alarma del sistema mismo. Esta alarma puede provenir de cualquier sistema de seguridad que haya instalado: antivirus, firewall o IDS (Intrusion Detection System).
- » La **segunda** opción es detectar una incidencia de seguridad sin que el sistema informe. ¿Cómo podemos detectar que una plataforma informática ha sufrido una incidencia de seguridad, ha sido infectada por un malware o ha sufrido un ataque si no hay ninguna alarma de aviso? Esto es posible si notas que el sistema informático actúa de una forma extraña.

EJEMPLO

Observas que hay archivos donde no solía haberlos o que faltan otras aplicaciones o archivos, o que se produce un cambio de hora/fecha, o percibes que el sistema se ha ralentizado, que efectúa reinicios inesperados o apagados repentinos, entre otras pequeñas señales. Todo ello nos puede dar pistas que indican que nuestro sistema informático podría estar **infectado** por alguna clase de malware o que podría haber sufrido alguna intrusión no permitida.

B. Solución de problemas siguiendo las indicaciones adecuadas

Una vez habéis detectada una incidencia de seguridad en el entorno digital, se tiene que actuar para evitar riesgos y posibles daños. Dependiendo de la situación, puedes encontrarte en uno de los siguientes escenarios:

- » Si tu empresa o institución **cuenta con un plan de contingencia**, este debería incluir un apartado específico con los procedimientos por seguir para resolver la incidencia. Como hemos comentado en diversas ocasiones, el plan está diseñado para garantizar la continuidad del negocio y proporciona instrucciones claras para minimizar los riesgos asociados a la incidencia. Esta es la situación ideal, especialmente en pymes.
- » Si **no existe un plan de contingencia o este no aborda la incidencia específica**, se tendrá que actuar por cuenta propia.

A continuación, se detallan las acciones que podemos llevar a cabo según el tipo de problema:

- » Si la incidencia proviene de una alerta del **antivirus**, sigue las sugerencias que este te proporcione. **Si el antivirus no logra eliminar la amenaza:**



Actualiza el antivirus

Es esencial que el software esté actualizado. Una vez hecho esto, volveremos a escanear el sistema.



Modo seguro

Si el malware reaparece después de reiniciar, intenta iniciar el sistema en **modo seguro** y ejecuta el antivirus desde allí.



Herramientas especializadas

Algunos proveedores de programas de seguridad ofrecen herramientas independientes para eliminar amenazas complejas. Estas suelen funcionar en línea y pueden ser útiles en casos difíciles.

- » Si se sospecha que algo no funciona bien, pero no se ha recibido alertas, se pueden revisar los **registros de eventos** del sistema:

- **Visor de eventos de Windows:** consulta los registros de seguridad, aplicaciones y sistema para identificar actividades sospechosas, como inicios de sesión inusuales o intentos de acceso fallidos. Puedes filtrar los eventos, ya que no es necesario auditarlos todos y esto podría afectar al rendimiento del sistema. Hay que centrarse en los eventos de seguridad más críticos.

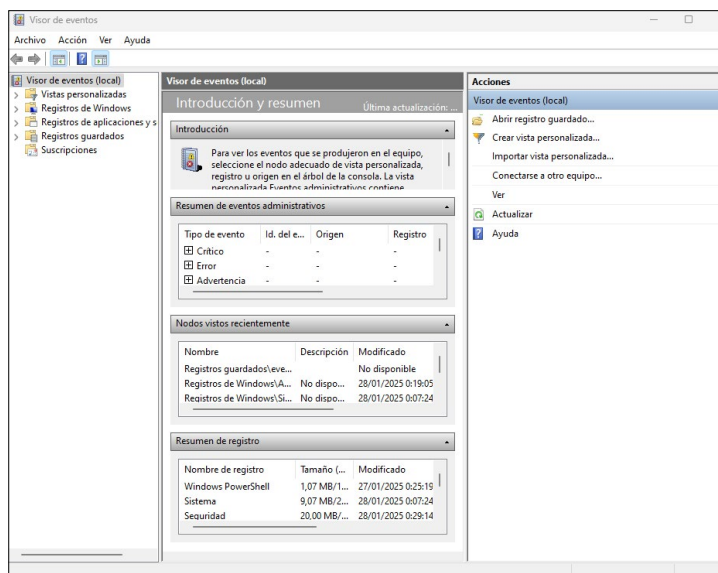


Fig. 7. Visor de eventos de Windows.

- **Revisión del cortafuegos (firewall):** si no se encuentra nada sospechoso en los registros de eventos, se pueden revisar los **registros del firewall**. Busca patrones inusuales, como conexiones entrantes o salientes no autorizadas.

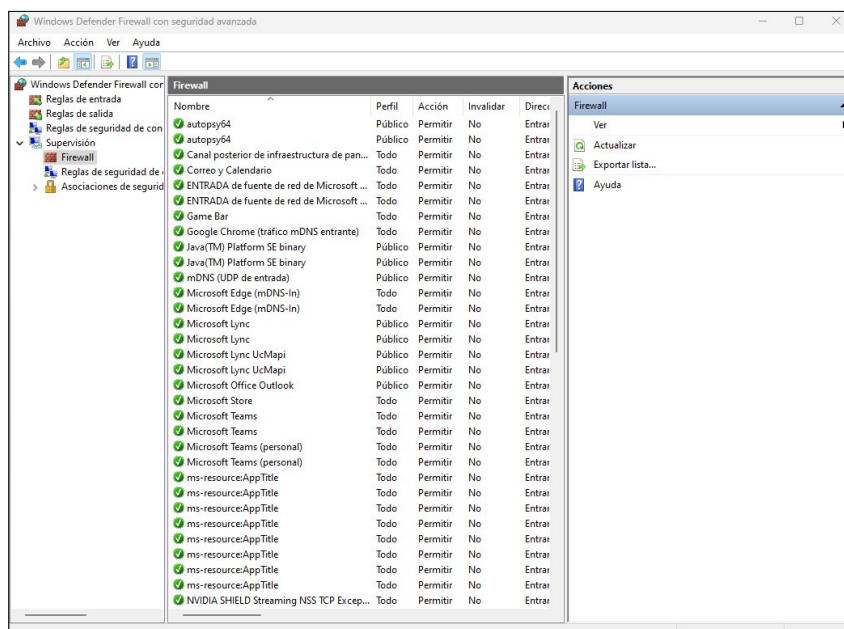


Fig. 8. Registros del firewall.

- **Procesos en ejecución:** si aún no has identificado el problema, puedes revisar los procesos en ejecución en el sistema. Abre el *Administrador de tareas* (Windows) o el *Monitor del sistema* (Linux/Mac) para ver los procesos activos. Investiga en Internet cualquier proceso desconocido. Algunos malware se camuflan como procesos legítimos. Si identificas un malware, busca instrucciones específicas para eliminarlo. Estas pueden incluir el uso de la consola de comandos y reiniciar el sistema.

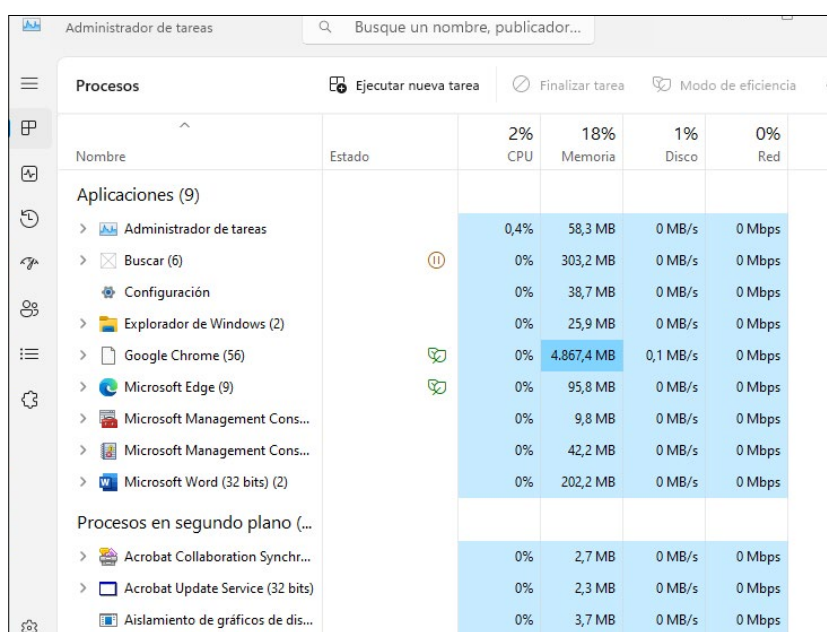


Fig. 9. Administrador de tareas de Windows.

- **Restauración del sistema:** si ninguna de las opciones anteriores resuelve el problema, puedes restaurar el sistema a un punto anterior: utiliza la función de **restauración del sistema** de tu sistema operativo y selecciona un **punto de restauración** creado antes de que ocurriera la incidencia. Es importante **crear puntos de restauración manualmente** en momentos en que el sistema funcione correctamente. Algunos sistemas los generan automáticamente ante cambios importantes.

Adicionalmente, sigue estos **consejos**:

Mantén la calma

Resolver incidencias de seguridad puede ser estresante, pero un enfoque metódico ayudará a evitar errores.

Documenta los pasos

Registra las acciones que se realizan para resolver la incidencia. Esto será útil para futuros problemas.

Busca ayuda si la necesitas

Si la incidencia es compleja o no estás seguro de cómo proceder, no dudes en contactar a un especialista en seguridad informática.

Mejora la prevención

Una vez resuelta la incidencia, revisa y mejora las medidas de seguridad del sistema para evitar en lo posible problemas futuros.

2.2. Comprensión y uso de la documentación técnica como soporte

Como hemos comentado anteriormente, resolver una incidencia de seguridad puede ser tan fácil como seguir las instrucciones detalladas de un plan de contingencia. Sin embargo, es importante tener en cuenta que estas instrucciones suelen ser técnicas y pueden incluir **vocabulario especializado**. Si encuentras términos o procedimientos que son difíciles de entender, puedes hacer lo siguiente:

- » **Utilizar el sistema de ayuda integrado:** la mayoría de los sistemas informáticos incluyen un sistema de ayuda que explica las funciones del sistema y proporciona instrucciones para realizar tareas varias. Por ejemplo, en Windows, simplemente escribiendo «ayuda», te aparecerá un asistente. La ubicación de esta ayuda varía según el sistema, pero suele ser accesible desde el menú principal o mediante una tecla de función (por ejemplo, F1 en Word).

```
$ uptime --help

Usage:
  uptime [options]

Options:
  -p, --pretty    show uptime in pretty format
  -h, --help      display this help and exit
  -s, --since     system up since
  -V, --version   output version information and exit

For more details see uptime(1).
```

Fig. 10. En sistemas de código abierto, se puede usar el comando `--help`.

- » **Consulta manuales o busca información en Internet:** si el sistema de ayuda no es suficiente, puedes consultar manuales técnicos o buscar información en Internet. Ten en cuenta que en Internet está todo, pero lo importante es saber buscar, ya que la información es a veces contradictoria. Por ello, es crucial seleccionar fuentes confiables, como páginas oficiales o foros reconocidos.
- » **Traduce la información si es necesario:** si no dominas el inglés, utiliza herramientas de traducción en línea para entender los documentos y las instrucciones. Ten en cuenta que, aunque han mejorado mucho durante los últimos años, las traducciones automáticas suelen ser erróneas con la terminología técnica.
- » **Sigue instrucciones de las herramientas de seguridad:** si no dispones de un plan de contingencia, las propias herramientas que detectaron la incidencia pueden proporcionar instrucciones para resolverla.
- » **Busca soluciones en Internet si no hay plan de contingencia:** si no tienes un plan de contingencia o este no es útil para la incidencia actual, busca soluciones en Internet. Seguramente, alguien más haya tenido el mismo problema, por lo que puedes encontrar guías o consejos en foros técnicos. Selecciona información de fuentes fiables y evita realizar cambios que no estén claramente justificados.
- » **Sigue las instrucciones al pie de la letra:** al seguir instrucciones técnicas, es crucial no desviarse de lo indicado. Cualquier modificación no autorizada puede generar problemas adicionales. Asegúrate de utilizar las versiones correctas del software y del sistema operativo, tal como se especifica en las instrucciones.

2.3. Registro y reporte de incidentes de seguridad

Si, por desgracia, no se dispone de ningún plan de contingencia o el plan no recoge la incidencia en cuestión, hace falta documentarla de forma correcta. Hay que recoger y describir en qué consiste la incidencia sufrida, cómo se ha detectado, cuándo se ha producido, qué efectos ha tenido y, sobre todo, **cómo se ha resuelto** para prepararte para posibles problemas en el futuro. Si para resolver la incidencia se han utilizado materiales diversos y fuentes de información diferentes, conviene documentarlas. Todo esto facilitará enormemente la resolución de ulteriores problemas.

Si en la empresa en cuestión hay un protocolo, es decir, **instrucciones sobre cómo desarrollar esta documentación**, hay que seguirlo a la hora de describir la nueva incidencia. Si no hay ningún protocolo, la documentación tendrá que incluir toda la información de una manera clara y muy estructurada. Se tiene que pensar que, en un futuro, es posible que otras personas lean esta información, de forma que es necesario que esté muy bien redactada, para que sea fácil de entender y seguir.

2 CASO PRÁCTICO



USO DE WIRESHARK PARA CAPTURAR TRÁFICO DE VISITAS A UNA PÁGINA WEB

El objetivo de esta práctica es aprender a utilizar Wireshark, una herramienta de análisis de tráfico de red, para capturar y analizar las solicitudes y las respuestas generadas al visitar una página web. Al finalizar, serás capaz de identificar paquetes HTTP/HTTPS, filtrar tráfico específico y comprender cómo se comunican los navegadores con los servidores web.

Descarga e instala Wireshark desde su página oficial: <https://www.wireshark.org/>

1. Abre Wireshark y selecciona la interfaz de red activa (por ejemplo, Wi-Fi o Ethernet).
2. Haz clic en *Start* para comenzar a capturar paquetes.
3. Abre tu navegador web: en Wireshark, asegúrate de que la captura de paquetes esté en curso.
4. Escribe la URL de una página web en el navegador para así ver la diferencia entre un paquete HTTP y HTTPS.
5. Presiona *Enter* para cargar la página.
6. Después de cargar la página, vuelve a Wireshark y haz clic en *Stop* para detener la captura.
7. En la barra de filtros de Wireshark, escribe «http» (HTTP), o bien «tls» o «ssl» (HTTPS).
8. Presiona *Enter* para aplicar el filtro.
9. Busca paquetes que muestren interacciones clave, como solicitudes de recursos o respuestas del servidor.
10. Observa los detalles de los paquetes en el panel inferior:
 - Dirección IP del servidor: identifica la IP del servidor web al que se está conectando el navegador.
 - Encabezados de protocolo: revisa los encabezados de solicitud y respuesta para obtener información sobre el tipo de datos transferidos, el método de la solicitud, el estado de la respuesta y más.
11. Haz clic derecho sobre un paquete HTTP o TLS relevante y selecciona *Follow > TCP Stream* o *Follow > HTTP Stream* según corresponda.
12. Esto mostrará la conversación completa entre el navegador y el servidor, permitiendo analizar el flujo de datos de principio a fin.

Responde a las siguientes preguntas:

- » ¿Qué diferencias observas entre el tráfico HTTP y HTTPS?
- » ¿Cómo identificas la dirección IP del servidor web en los paquetes capturados?
- » ¿Qué información puedes obtener de los encabezados HTTP?

03 Seguridad frente a software malicioso

Un software malicioso está diseñado para **dañar el ordenador**, y puede incluir virus, troyanos, gusanos o programas espía, entre otros. Una vez dentro del sistema, estos programas pueden extraer información confidencial o cumplir distintos propósitos, como permitir el acceso no autorizado a terceros.



¿SABÍAS QUE...?

Hay muchos tipos diferentes de malware. Las técnicas que utilizan para entrar en los sistemas y las acciones que llevan a cabo también son muchas y muy diversas. Por lo tanto, es fundamental que tomes precauciones varias y combines diferentes métodos de protección. Principalmente, es imprescindible instalar un **programa antivirus** en el ordenador para garantizar su seguridad. Hay que tener en cuenta que en un ordenador se introducen memorias USB o discos extraíbles y, sobre todo, que, si está conectado en Internet, está sometido a la peligrosidad del malware. Por lo tanto, será imprescindible que tu sistema informático esté debidamente protegido contra este tipo de software malicioso.

Lo primero que debes hacer para proteger el sistema es instalar correctamente el sistema operativo con las aplicaciones y las actualizaciones correspondientes, sobre todo las de seguridad. También hará falta una buena política de copias de seguridad, tanto en cuanto a los datos guardados como en cuanto a la configuración del sistema (tema que hemos tratado en la Unidad 2). De este modo, en caso de producirse una incidencia de seguridad, la recuperación del sistema será lo más rápida y eficaz posible.

Pero todas estas medidas sirven de poco si no se instala un **antivirus**, que se tiene que mantener actualizado en todo momento. También hay que reforzar la seguridad con otras utilidades, como los **cortafuegos** (firewalls), que además pueden combinarse con programas que **monitorizan el tráfico** de información a través de la red.

Estas son, a grandes rasgos, las actuaciones que hay que seguir para proteger el sistema del malware. De todos modos, hay que aceptar que tomar todas las medidas de seguridad mencionadas no garantiza una seguridad total y absoluta. Por lo tanto, la **política de backups** es importantísima. En caso de que no sea posible evitar completamente la infección del entorno informático, al menos se garantizará al máximo una recuperación rápida y efectiva tras una incidencia de seguridad.

Especialmente, hay que mencionar la diferencia que hay entre los sistemas que utilizan **software propietario**, como Windows (Microsoft), y los que utilizan **software libre**, como los sistemas operativos de Linux (Ubuntu, Fedora, Debian...). Estos últimos son mucho más seguros en cuanto a la posible infección de virus y a las intrusiones. Por lo tanto, este factor debe tenerse en cuenta al instalar un sistema, ya que la seguridad se ha convertido en un aspecto fundamental de los sistemas informáticos en la actualidad.

Finalmente, es importante hablar a los piratas informáticos, conocidos como hackers, cuyo objetivo es infiltrarse en los sistemas informáticos con diversos fines, ya sea simplemente para acceder o para llevar a cabo acciones **perjudiciales para el sistema**. En diversas ocasiones, estos ciberdelincuentes recurren a técnicas como la ingeniería social o la suplantación de identidad, en lugar de utilizar malware que explota vulnerabilidades de seguridad del entorno digital. Esto hace que la protección sea aún más complicada, ya que no basta con mantener el sistema bien protegido, sino que también es necesario navegar por Internet con precaución, prestando una atención especial a las páginas web que visitamos y, sobre todo, a los datos que se comparten.

IMPORTANTE

Es necesario tener el **sistema muy protegido**. Por lo tanto, es fundamental tener claro de quién hay que protegerse y qué es lo que se quiere proteger. También es importante conocer los riesgos a los que está expuesto nuestro sistema, el nivel de propagación y los posibles daños que el software malicioso puede causar. Esta es, por tanto, la primera tarea que debe realizarse.

El malware es todo software que se instala en nuestro ordenador, sin nuestro consentimiento ni conocimiento, **con el fin de perjudicarlo o de obtener un beneficio**. Este último caso es el más habitual, de forma que las acciones del software malicioso cada vez son más sofisticadas y difíciles de identificar. Existen diversos tipos de software malicioso, lo que hace que su clasificación resulte compleja. Sin embargo, es posible identificar los tipos más comunes, entre los cuales se encuentran los siguientes:

3.1. Virus

A. Virus de sector de arranque

El disco duro de tu ordenador tiene un sector cuyo único propósito es **orientar al sistema operativo**, para que este pueda iniciar la interfaz. Un virus de sector de arranque daña o controla el sector de arranque del disco, inutilizando al equipo. Los atacantes suelen diseminar este tipo de virus mediante un dispositivo USB malintencionado. El virus se activa cuando los usuarios conectan el dispositivo USB y arrancan su equipo.

Algunos **ejemplos** de virus de este tipo son:

	Michelangelo	Sobrescribía sectores del disco, causando la pérdida de datos.
	Stoned	Uno de los primeros virus de este tipo. Mostraba el mensaje «Your PC is now stoned!» y podía infectar disquetes y discos duros.
	Form	Infectaba disquetes y discos duros, mostrando mensajes en fechas específicas y causando problemas con el arranque del sistema.
	NYB (New York Boot)	Infectaba el sector de arranque de disquetes y discos duros, ralentizando el sistema y dificultando su eliminación.

B. Virus de script

La mayoría de los navegadores cuentan con defensas contra los scripts malintencionados, pero los navegadores más antiguos u obsoletos tienen vulnerabilidades que pueden permitir a un delincuente cibernético ejecutar código en el dispositivo local.

Algunos **ejemplos** son:

	ILOVEYOU (Love Bug)	Se propagaba por correo electrónico con un archivo adjunto de VBScript (.vbs). Al abrirlo, sobrescribía archivos y enviaba copias del virus a todos los contactos de la víctima.
	Anna Kournikova	Un virus de script en Visual Basic Script (VBS) que engañaba a los usuarios con la promesa de una imagen de la tenista. Se enviaba automáticamente a todos los contactos del usuario infectado.

C. Secuestrador del navegador

Hay virus que pueden cambiar la configuración de tu navegador y funcionan **secuestrando** los enlaces favoritos de este, la URL de la página de inicio y tus preferencias de búsqueda, para redirigirte a una página malintencionada, que podría ser una web de phishing o de adware usada para robar datos o para ganar dinero por parte del atacante.

Algunos **ejemplos** son:



Ask Toolbar

Un complemento que cambia la página de inicio y el motor de búsqueda predeterminado a Ask.com, a menudo instalado junto con software gratuito.

Babylon Toolbar

Secuestra el navegador redirigiendo las búsquedas a Babylon.com e instala una barra de herramientas difícil de eliminar.

D. Virus residentes

Estos virus se incrustan en la memoria del ordenador y permanecen ocultos hasta ser activados. Este malware puede permanecer en hibernación hasta una fecha u hora específicas, o hasta que un usuario ejecuta una acción determinada.

Algunos **ejemplos** son:



CIH (Chernobyl Virus)

Infectaba archivos ejecutables de Windows (PE, Portable Executable). Podía sobrescribir la BIOS, dejando el sistema inutilizable.

Sality

Un virus polimórfico residente en memoria que infecta archivos .exe y .scr. Desactiva programas de seguridad y abre puertas traseras para otros tipos de malware.

E. Virus de acción directa

Cuando un usuario ejecuta un archivo aparentemente inocuo, pero que en realidad contiene código malintencionado, los virus despliegan su carga útil **de inmediato**. Estos tipos de virus pueden permanecer suspendidos hasta que se realiza una acción específica o hasta que transcurra un periodo de tiempo determinado.

Algunos **ejemplos** son:

	Vienna Virus	Infecta archivos ejecutables (.exe) y, al ejecutar el archivo infectado, se activa de forma inmediata y corrompe otros archivos.
	Cascade Virus	Infecta los archivos .com. Una vez activado, hace que las letras en la pantalla «caigan» hacia la parte inferior, dañando la información.
	Virus polimórfico	Los creadores del malware pueden usar código polimórfico para cambiar la huella del programa y así evitar su detección. Los virus polimórficos dificultan a los antivirus detectarlos y eliminarlos.
	Storm Worm	Apareció en 2007 como un troyano distribuido por correo electrónico con asuntos engañosos. Cambiaba su código constantemente para evitar ser detectado por los antivirus.
	Marburg	Infecta archivos ejecutables (.exe) y utiliza técnicas de polimorfismo para cifrar su código. Se replica alterando su firma cada vez, lo que complica su detección.

F. Virus que infecta archivos

Para persistir en un sistema, el autor de la amenaza emplea **virus inyectores con código malintencionado para infectar archivos clave** que ejecutan el sistema operativo o programas importantes. Cuando el sistema arranca o se ejecuta el programa, el virus se activa.

G. Virus multipartitos

Estos programas malintencionados se **diseminan** por las redes de otros sistemas, bien copiándose a sí mismos, o bien inyectando código en recursos informáticos esenciales.

Algunos **ejemplos** son:

	One_Half	Este virus infectaba el sector de arranque del disco duro y los archivos ejecutables. Gradualmente cifraba partes del disco duro, dificultando el acceso a los datos. Si se intentaba eliminar solo una parte del virus, podía regenerarse desde la otra.
	Tequila	Infectaba archivos ejecutables (.exe) y el sector de arranque. Se replicaba fácilmente y era difícil de eliminar porque podía restablecerse desde cualquiera de las áreas infectadas. Fue conocido por mostrar un mensaje visual específico al activarse.

Virus de macros

Los archivos de Microsoft Office pueden ejecutar macros, y estas macros se pueden usar para descargar malware adicional o ejecutar código malintencionado. Los virus macro despliegan su carga útil cuando se abre el archivo y se ejecutan las macros.

Concept

Uno de los primeros virus de macros conocidos. Infectaba documentos de Microsoft Word y se propagaba al abrir un documento infectado. Cambiaba las configuraciones del programa y replicaba la macro maliciosa en otros documentos.

Melissa

Uno de los virus más famosos de la década de 1990. Se propagaba a través de correos electrónicos con un archivo adjunto infectado. Al abrir el archivo, el virus infectaba Microsoft Word y enviaba copias del virus a los contactos de correo electrónico del usuario.

**¿SABÍAS QUE...?**

Uno de los tipos de malware más peligrosos en la actualidad es el **ransomware**. Se trata de un programa malicioso que cifra los archivos del usuario y exige un pago para su recuperación. Funciona de la siguiente manera:

- 1. Infección inicial:** puede llegar a través de correos electrónicos maliciosos, archivos adjuntos infectados o descargas de sitios no confiables.
- 2. Cifrado de datos:** una vez dentro del sistema, el ransomware cifra documentos, imágenes y bases de datos, dejando los archivos inaccesibles.
- 3. Demanda de rescate:** aparece un mensaje en pantalla exigiendo el pago de un rescate, normalmente en criptomonedas, para recuperar los archivos.
- 4. Consecuencias:** sin una copia de seguridad, la víctima puede perder su información de forma permanente.

Estas son algunas claves para protegerse del ransomware:

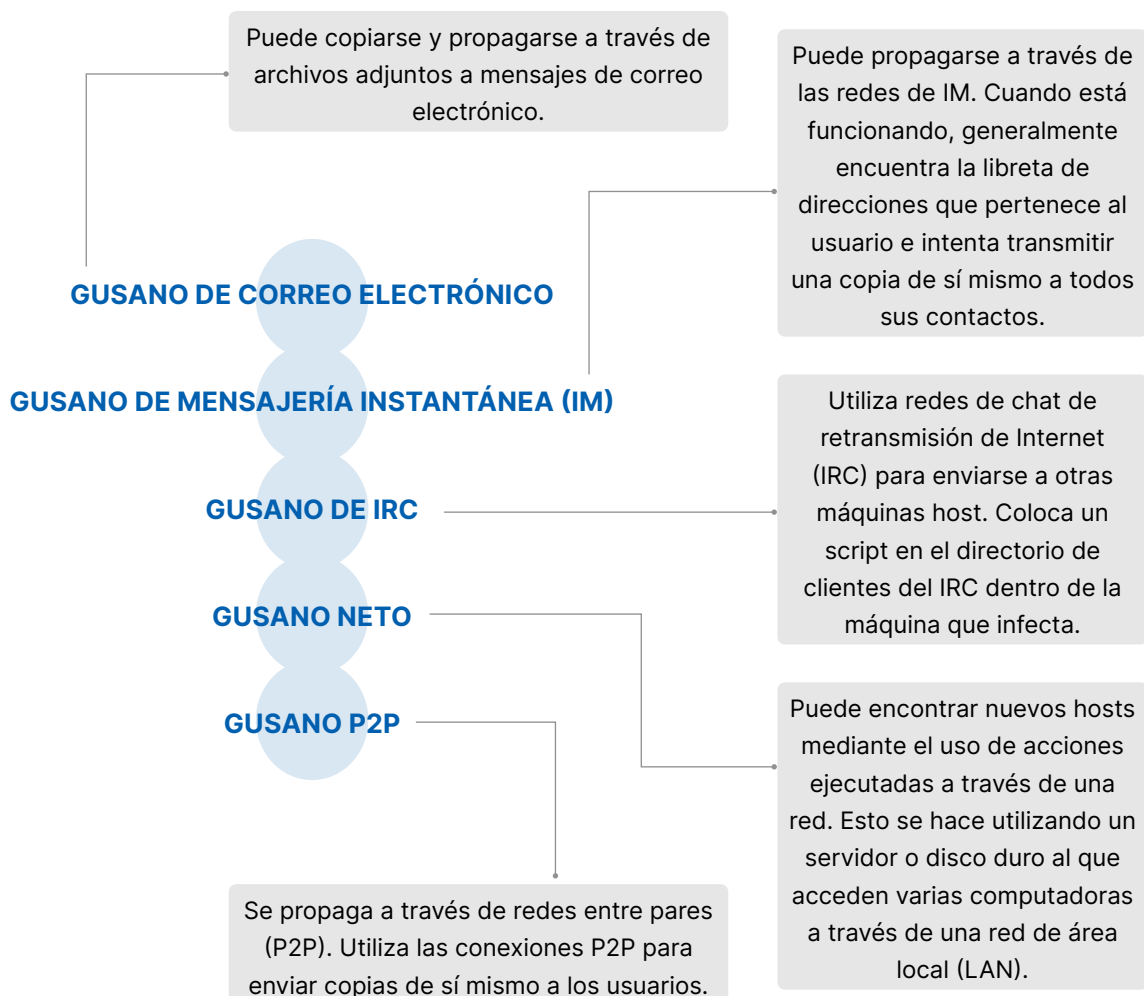
- » Realizar copias de seguridad periódicas en sistemas offline o en la nube.
- » No abrir correos electrónicos sospechosos ni descargar archivos de remitentes desconocidos.
- » Mantener los sistemas actualizados y aplicar parches de seguridad.
- » Utilizar software de protección contra ransomware, como soluciones de detección temprana.
- » Nunca pagar el rescate, ya que no garantiza la recuperación de los datos y financia futuras actividades delictivas.

3.2. Gusanos o worms

Un **gusano** es un programa malicioso que se replica a sí mismo y se propaga automáticamente a través de una red. El gusano explota las vulnerabilidades en tu software de seguridad para robar información confidencial, instalar puertas traseras que se pueden utilizar para acceder al sistema, corromper archivos y acometer otros tipos de daño.

Los gusanos consumen **grandes volúmenes de memoria**, así como **ancho de banda**. Esto hace que los servidores, los sistemas individuales y las redes se sobrecarguen y funcionen mal. Sin embargo, un gusano es diferente de un virus, ya que puede funcionar solo, mientras que un virus necesita una computadora host.

Los distintos **tipos de gusanos** son:



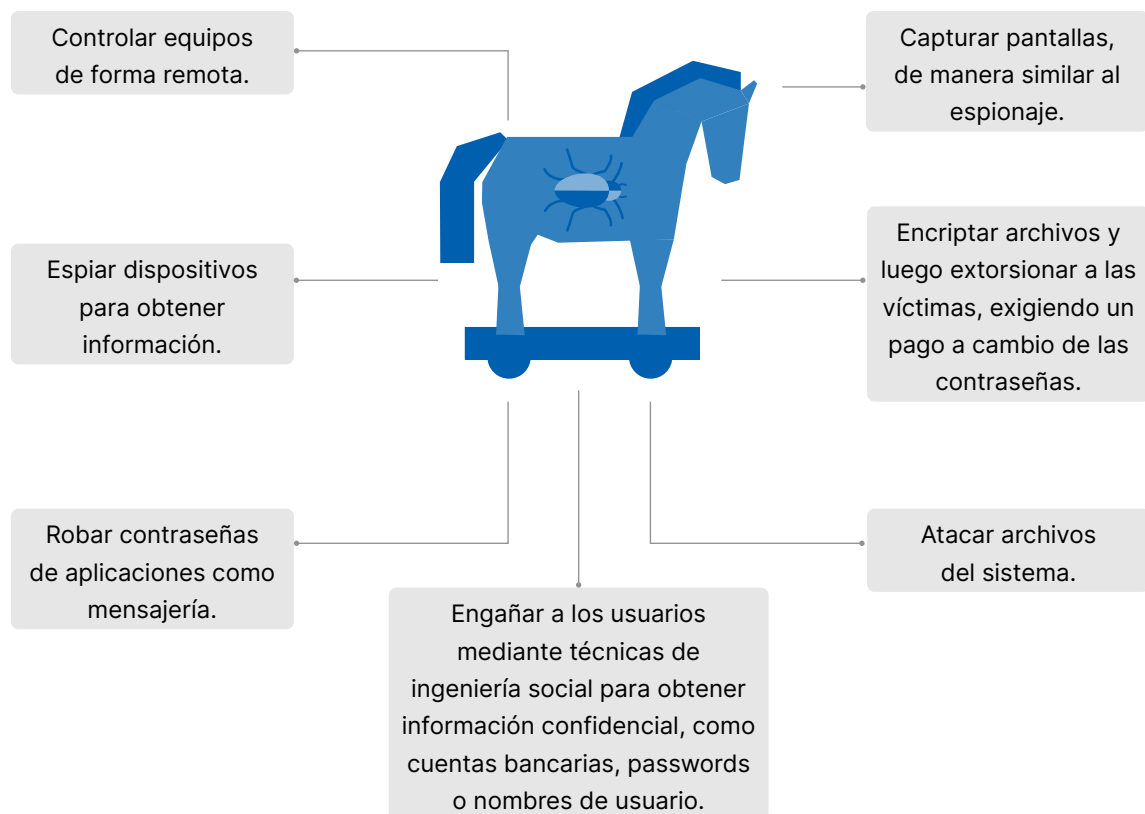
3.3. Caballos de Troya

No se consideran virus, porque no infectan otros ficheros para reproducirse ni tampoco hacen copias de ellos mismos para propagarse, como hacen los gusanos. El objetivo principal de estos programas es **infiltrarse en el ordenador e instalar otros programas que permitan el control remoto del sistema desde equipos externos**. Llegan al ordenador disfrazados de software aparentemente inofensivo, pero, al ejecutarse, instalan de manera encubierta un segundo programa: el caballo de Troya.

En general, los caballos de Troya son programas que se ocultan en imágenes o archivos multimedia (audio o vídeo) porque se pueden instalar fácilmente.

Los efectos de los caballos de Troya pueden ser muy peligrosos. Como los virus, tienen la capacidad de **eliminar ficheros o destruir la información del disco duro**. Además, pueden interceptar y recopilar datos confidenciales para enviarlos a una dirección externa sin el conocimiento del usuario. También tienen la capacidad de abrir puertos de comunicación, lo que facilita el acceso remoto al ordenador por parte de terceros, permitiéndoles tomar el control del sistema de manera no autorizada.

Algunas de las **acciones más comunes** de los caballos de Troya son las siguientes:



Algunos **ejemplos** son:



Zeus (Zbot)

Diseñado para robar información bancaria, como credenciales de inicio de sesión y datos de tarjetas de crédito. Se propaga a través de emails de phishing y sitios web comprometidos. Puede registrar pulsaciones de teclas (keylogging) y capturar pantallas.

Emotet

Originalmente un troyano bancario, evolucionó para convertirse en una plataforma de distribución de malware. Se propaga a través de correos electrónicos maliciosos con documentos adjuntos infectados. Permite la instalación de otros tipos de malware, como ransomware.

3.4. Bombas lógicas

Las bombas lógicas, estrictamente hablando, tampoco se consideran virus, ya que no se reproducen ni son programas independientes, sino **segmentos ocultos** dentro de otros programas. Su objetivo es destruir los datos de un ordenador o causar otros tipos de daño, que pueden llegar a ser muy destructivos.

3.5. Falsas alarmas o hoaxes

No son virus, sino **mensajes de correo electrónico engañosos**. Se difunden masivamente por Internet (spam) y generan alarma sobre supuestas infecciones de virus y amenazas dirigidas a los usuarios. Las falsas alarmas suelen ganarse la confianza de las personas, ya que proporcionan datos que parecen reales y sugieren una serie de acciones que seguir para eliminar la supuesta infección. Obviamente, no es necesario perder el tiempo con estas advertencias ni seguir las instrucciones; simplemente, se debe borrar el mensaje.

3.6. Spyware

DEFINICIÓN

Un **programa spyware o espía** es un software malicioso que recopila información de una plataforma informática y la envía a otro sistema externo sin el conocimiento ni el consentimiento del propietario del dispositivo. Este tipo de software se instala automáticamente en un dispositivo electrónico y se ejecuta cada vez que este se enciende, consumiendo recursos del **procesador** y la **memoria RAM**, lo que reduce el rendimiento del equipo. Además, monitorea el uso de Internet, mostrando anuncios personalizados basados en la actividad del usuario en la red.

La función principal de este tipo de programas es recopilar datos sobre el usuario, como hábitos de navegación, contraseñas, números de tarjetas de crédito, mensajes, contactos, direcciones IP, DNS, sitios web visitados, descargas realizadas y cookies, entre otros. Esta información se suele vender a empresas interesadas, ya sean publicitarias o de otro tipo. Sin embargo, también ha sido utilizada por organismos oficiales para recopilar datos en investigaciones relacionadas con delitos de todo tipo.

A. Formas de instalación del spyware

El spyware puede **infiltrarse** en un sistema de varias maneras:

Caballos de Troya	Programas maliciosos que se disfrazan de software autorizado.
Páginas web maliciosas	Contienen controles ActiveX o códigos que explotan vulnerabilidades del sistema.
Software gratuito o de prueba	Aplicaciones freeware o shareware descargadas de Internet que contienen spyware oculto. El freeware es un software distribuido de forma gratuita, pero con una licencia de uso restringida. Por lo general, no permite la modificación del código fuente. El shareware, por su parte, es un software que se distribuye de manera gratuita por un tiempo limitado o con funcionalidades restringidas. Después del periodo de prueba, el usuario debe pagar para acceder a la versión completa.



¿SABÍAS QUE...?

Además de recopilar información sensible, el spyware también **consume ancho de banda** al transmitir datos a través de Internet, lo que puede ralentizar la velocidad de transferencia de datos y afectar al rendimiento general del sistema.

Algunos ejemplos de spyware son:

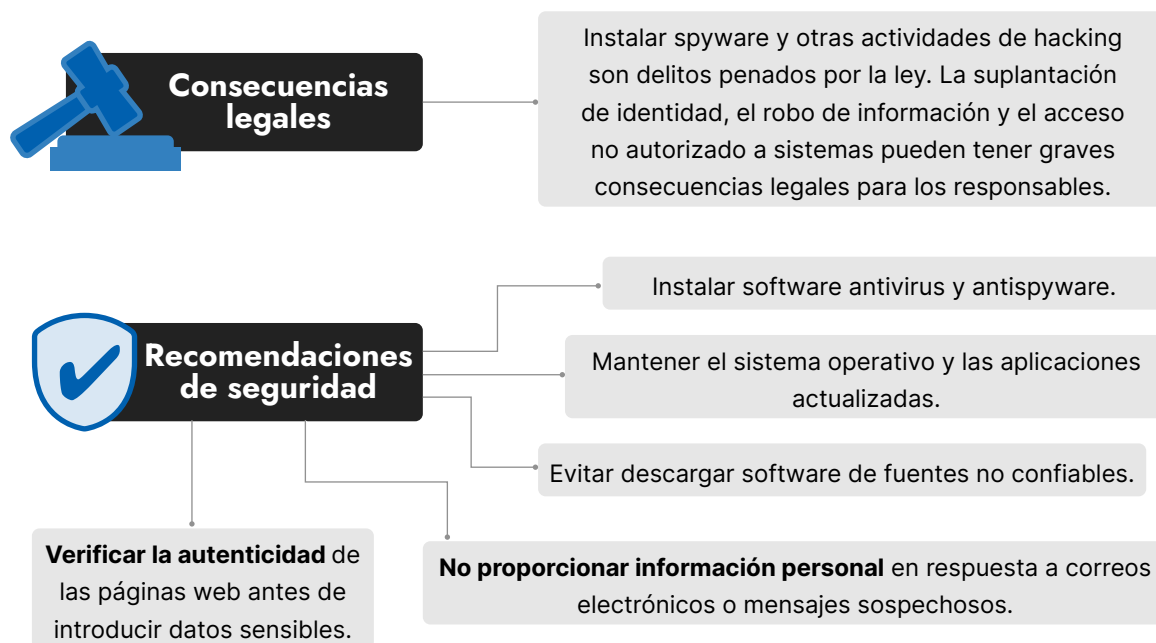
- » **Keyloggers:** programas diseñados para registrar las pulsaciones del teclado, como Phoenix Keylogger o Refog Keylogger.
- » **Adware con funciones espía:** software que muestra anuncios, pero también recopila datos, como CoolWebSearch o Gator (GAIN).
- » **Trojans espía:** malware que permite el acceso remoto al dispositivo infectado, como FinFisher o Spyrix.

- » **Software espía comercial:** herramientas «legales» diseñadas para monitorear dispositivos, como:
 - **mSpy:** usado para monitorear teléfonos móviles.
 - **FlexiSPY:** para rastrear actividades en dispositivos móviles y computadoras.
- » **Spyware bancario:** diseñado para robar credenciales de banca en línea, como:
 - **SpyEye:** roba datos financieros.
 - **Zeus:** troyano bancario muy conocido.
- » **Cookies:** aunque no son spyware en sí mismas, algunas cookies monitorean de forma extensa los hábitos de navegación de los usuarios.
- » **Pegasus:** spyware de uso militar desarrollado por NSO Group, utilizado para espiar teléfonos móviles de forma remota, famoso por ser utilizado en políticos y gente famosa.
- » **DarkComet:** un RAT (herramienta de acceso remoto) que actúa como spyware, usado para el espionaje general.
- » **HawkEye:** diseñado para extraer credenciales y monitorear la actividad del usuario en la computadora.

B. Hackers y métodos maliciosos

Además del spyware, existen otras amenazas relacionadas con los **hackers**, quienes utilizan técnicas varias para acceder a sistemas y datos sin autorización. Algunos de estos métodos son:

- » **Ingeniería social:** técnicas que buscan manipular a los usuarios para obtener información confidencial. Esto puede incluir:
 - **Suplantación de identidad (phishing):** se hacen pasar por una empresa legal, como un banco o una compañía de servicios, para solicitar información personal.
 - **Llamadas telefónicas fraudulentas:** el atacante intenta obtener datos confidenciales engañando a la víctima.
- » **Explotación de vulnerabilidades:** intentan aprovechar fallos de seguridad en sistemas operativos o aplicaciones para acceder a un sistema.



3.7. Características comunes, peligrosidad y propagación

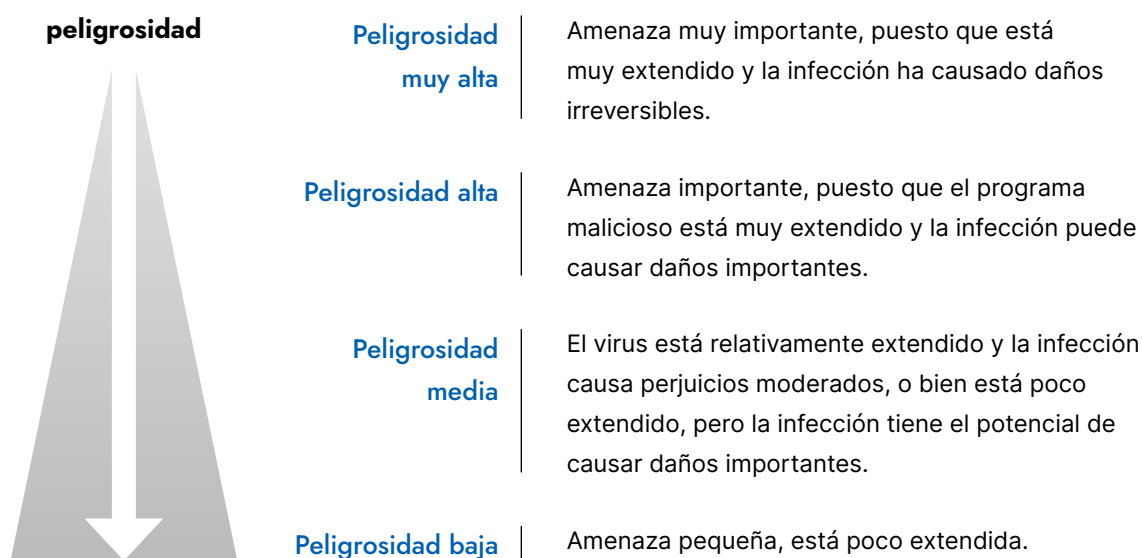
Existen muchos tipos de malware, pero todos comparten tres principios básicos que los definen:

- » **Son dañinos:** siempre causan problemas al dispositivo que infectan. Sin embargo, este daño no siempre implica la destrucción o corrupción de archivos o componentes del sistema. El perjuicio puede ser **implícito**, como cuando el malware solo quiere robar información, alterar datos o consumir recursos del sistema. Por ejemplo, puede agotar la **memoria principal (RAM)**, el **tiempo de procesador (CPU)** o el **ancho de banda de la red** para minar criptomonedas, lo que afecta negativamente al rendimiento del equipo.
- » **Son autorreproductores:** una de las características más distintivas de este tipo de software es su capacidad para **crear copias de sí mismo**. Esta capacidad de reproducción no es común en las aplicaciones convencionales y es lo que permite que el malware se propague rápidamente a otros entornos digitales.
- » **Son subrepticios:** el malware utiliza diversas técnicas para **ocultar su presencia** y evitar que el usuario lo detecte. Algunas de estas técnicas incluyen:
 - Tener un **tamaño reducido** para pasar desapercibido a simple vista.
 - Manipular los resultados de las solicitudes del sistema operativo, como ocultar su tamaño real o los atributos del archivo infectado.
 - Desactivar herramientas de seguridad, como antivirus o firewalls, para así hacer más difícil su detección.

Estas características hacen que el software malicioso sea especialmente peligroso y difícil de eliminar. Su capacidad para dañar, autorreplicarse y ocultarse lo convierte en una amenaza constante para la seguridad de los sistemas y la privacidad de los usuarios.

La **peligrosidad** es el riesgo que corre un sistema de ser infectado por este tipo de software en cualquiera de sus variantes. Lógicamente, la peligrosidad puede variar.

Podemos diferenciar varios tipos de peligrosidad:



El nivel de propagación del malware indica cuán extendido está. La propagación de un virus se determina mediante la **tasa de infección**, es decir, el porcentaje de dispositivos infectados en relación con el total de elementos analizados.

El grado de propagación de un virus puede adoptar diferentes valores:

- » **Epidemia:** el porcentaje de ordenadores o elementos examinados e infectados con el programa malicioso es del **10 % o superior**.
- » **Propagación alta:** el porcentaje de ordenadores o elementos examinados e infectados con el programa malicioso es **superior al 7,5 % pero inferior al 10 %**.
- » **Propagación media:** el porcentaje de ordenadores o elementos examinados e infectados con el programa malicioso es **superior al 1 % pero inferior al 7,5 %**.
- » **Propagación baja:** el porcentaje de ordenadores o elementos examinados e infectados con el programa malicioso es **inferior al 1 %**.

El nivel de daños que provoca un malware es un indicativo del perjuicio que está provocando al dispositivo informático. Como se ha comentado anteriormente, estos perjuicios pueden ser más o menos importantes: aparición de mensajes por pantalla, pérdida o alteración de información, sistemas colapsados, imposibilidad de funcionamiento y un largo etcétera. El **nivel de daños** de un virus puede adoptar diferentes valores:

- » **Muy alto:** ocasiona perjuicios graves. Por ejemplo, destrucción o modificación de archivos, formateo de discos, envío de información a terceros, generación de gran tráfico en servidores, disminución del rendimiento de los sistemas, apertura de fallos de seguridad, etc.
- » **Alto:** cualquier programa malicioso, aunque parezca inofensivo, ocasiona algún perjuicio al usuario. Se incluyen aquellos que no realizan acciones destructivas.

DAÑOS/ PROPAGACIÓN	BAJA	MEDIA	ALTA	EPIDEMIA
MUY ALTO	Media	Alta	Muy alta	Muy alta
ALTO	Baja	Media	Alta	Muy alta

Tabla 2. Daños y propagación.

3.8. Formas y estrategias que emplea el malware para atacar

Previamente, hemos conocido los diferentes tipos de malware, su grado de propagación y los daños que ocasionan. Es importante ahora entender los métodos y medios que suelen utilizar para infectar un dispositivo, siendo los más comunes los siguientes:

A. Unidades de disco portátiles (discos, pendrives, tarjetas SD, etc.)

Se trata de dispositivos de almacenamiento que contienen archivos, documentos o información. Si estas unidades están infectadas y se conectan a un ordenador, pueden infectar a este último.



Fig. 11. Disco duro externo.

B. Redes locales de ordenadores

Es un conjunto de ordenadores conectados entre sí para facilitar la transferencia de información. Si un ordenador de una red está infectado, el malware puede propagarse rápidamente a los otros dispositivos que están conectados a la misma red.

C. Internet

A través de la transferencia de información y la conexión global de ordenadores, el malware puede infiltrarse en un sistema de mil y una maneras.

- » **Email:** los mensajes de correo pueden incluir archivos adjuntos infectados. Cuando el destinatario abre el archivo, el malware se activa y puede infectar el sistema.
- » **Páginas web:** hay webs que pueden contener controles ActiveX o applets de Java, que son programas que pueden estar infectados. Al visitar una página maliciosa, el malware puede descargarse e instalarse en el ordenador. En el pasado, los ataques se realizaban a través de **controles ActiveX o applets de Java**, pero estos vectores de infección están **obsoletos** debido a las medidas de seguridad de los navegadores actuales. Hoy en día, los ataques suelen aprovechar scripts, vulnerabilidades del navegador y phishing.
- » **Descarga de archivos (FTP):** el protocolo **FTP (File Transfer Protocol)** permite transferir archivos entre ordenadores, aunque hoy en día **está obsoleto** y ha sido reemplazado por protocolos más seguros como **SFTP (Secure FTP) y FTPS (FTP con SSL/TLS)**. Si un archivo descargado contiene malware, aún puede infectar el sistema, por lo que es importante descargar archivos solo desde fuentes confiables.
- » **Newsgroups y foros:** estos grupos permiten debatir temas y compartir información. En el pasado, era común encontrar mensajes con **archivos adjuntos infectados** que, al abrirse, ejecutaban malware en el sistema. Sin embargo, hoy en día su uso ha disminuido considerablemente, y las **nuevas amenazas** se encuentran en redes sociales (WhatsApp, Telegram, X, Instagram o TikTok, entre otras...), donde los atacantes propagan **enlaces con archivos infectados** para comprometer los dispositivos.

3.9. Métodos de infección

El software malicioso utiliza varios métodos para infiltrarse en un sistema:

Ejecución junto con un programa legítimo	Incrustación en programas no infectados	Explotación del sector de arranque
El malware puede iniciarse automáticamente cuando el usuario instala y ejecuta un programa aparentemente legítimo.	Puede ocultarse dentro de un programa sano y activarse cuando el usuario ejecuta dicho programa.	Puede alojarse en el sector de arranque de un disquete, una memoria USB o un disco duro externo. Cuando el usuario inicia el ordenador con el dispositivo conectado, el malware se ejecuta automáticamente.

3.10. Circunstancias en las que tu sistema está en riesgo de ser infectado y cómo evitarlo

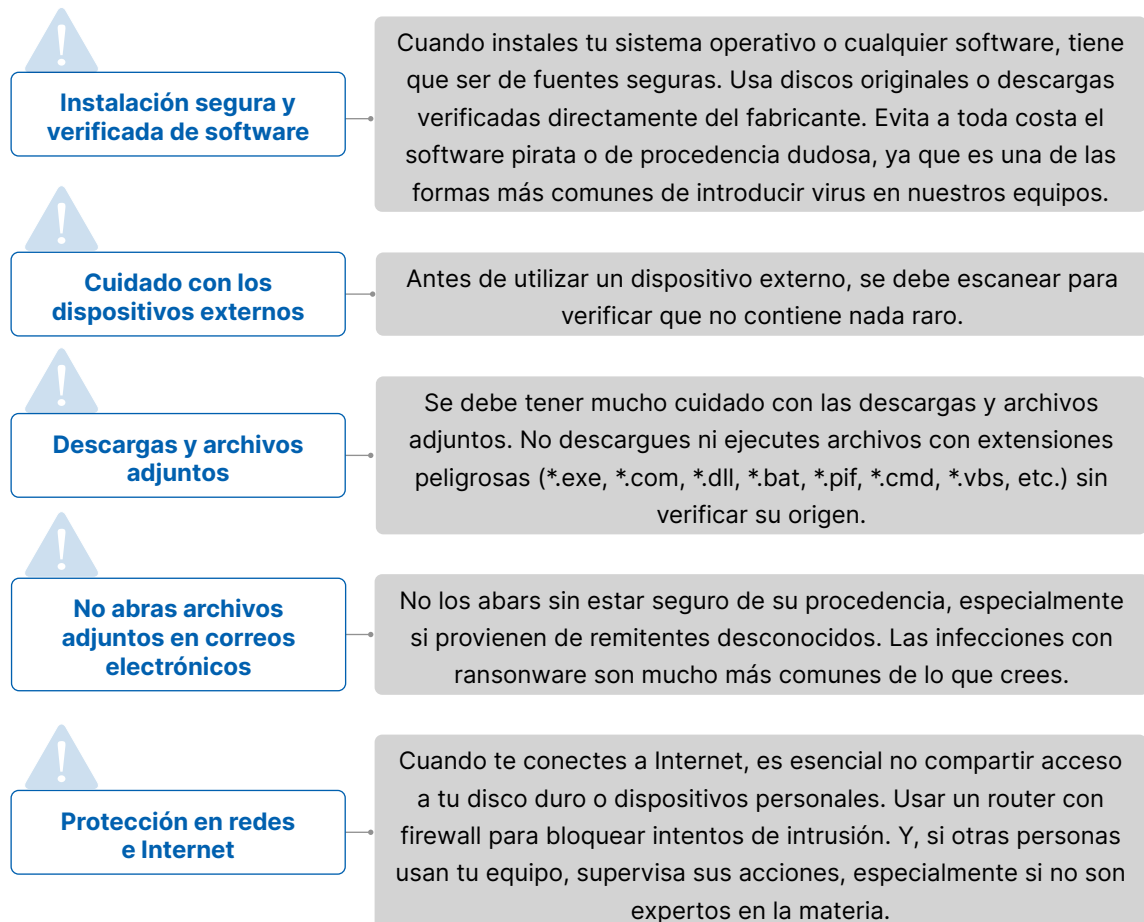
Hay momentos en los que, sin darnos cuenta, exponemos nuestro ordenador a posibles infecciones por todo tipo de virus. A veces, son acciones cotidianas las que generan un riesgo importante, como:

- » **Instalar programas «pirata» o de dudosa procedencia:** si usas copias no originales de programas de pago o instalas software desde dispositivos USB que no están protegidos, estás jugando a la ruleta rusa. Esos dispositivos podrían estar infectados sin que lo sepas.
- » **Ejecutar programas de otros equipos sin revisarlos:** a todos nos han pasado un programa o archivo desde otro ordenador. Si no te aseguras de que ese equipo está limpio de virus, podrías estar introduciendo malware en tu ordenador sin saberlo.
- » **Descargar archivos de Internet o emails sin precaución:** Internet está lleno de riesgos. Si descargas programas o abres archivos adjuntos de correo sin confirmar que la fuente es confiable, podría ser peligroso.

La clave está en **ser precavido**. Antes de instalar, descargar o hacer clic en algo, piénsalo dos veces. Un momento de duda puede ahorrarte muchos problemas.

Proteger tu sistema contra el malware **no tiene por qué ser complicado**. Con algunas buenas prácticas y un poco de atención, se puede reducir de forma importante el riesgo de infección.

A. Consejos prácticos y fáciles



B. Consejos generales para navegar seguro

- » Haz copias de seguridad periódicas de tus archivos importantes. Así, si algo sale mal, no perderás todo.
- » Instala un buen antivirus y mantenlo actualizado. Es tu primera línea de defensa contra el malware.
- » No olvides actualizar tu sistema operativo y tus programas. Las actualizaciones suelen incluir parches de seguridad que cierran vulnerabilidades.

C. Protección contra gusanos (worms)

Los gusanos son un tipo de malware que se propaga rápidamente, especialmente a través de emails. Para evitarlos:

- » Mantén tu sistema y tus programas actualizados.
- » No abras archivos adjuntos sospechosos, especialmente si el remitente es desconocido.
- » Configura tu sistema para mostrar las extensiones de los archivos. Así podrás identificar archivos peligrosos como *.exe o *.vbs.
- » Elimina directamente correos de publicidad o con asuntos extraños.

D. Servicios de correo con protección antivirus

Usa servicios de correo como **Gmail o Outlook**, que escanean automáticamente los archivos adjuntos en busca de malware. Y, por supuesto, evita abrir correos con contenido sospechoso o títulos extraños.

E. Protección contra virus de macros en documentos

Algunos virus se esconden en documentos de Word o Excel que usan macros. Para protegerte:

- » No habilites **macros** en documentos de fuentes desconocidas.
- » Configura Word y Excel para que te **avisen** antes de ejecutar macros.
- » Si **sospechas** que un documento está infectado, elimina la plantilla Normal.dot en Word, ya que es un punto común de propagación.

La seguridad informática no es solo cosa de expertos. Con un poco de sentido común y estas prácticas sencillas, puedes proteger tu sistema y tus datos sin complicarte demasiado. Recuerda: más vale prevenir que lamentar.

3.11. Antivirus

Un antivirus, siempre que esté **actualizado**, es como un guardián que protege nuestro equipo de amenazas de todo tipo de malware. Pero no basta con instalarlo, como hemos dicho anteriormente, sino que hay que configurarlo y mantenerlo actualizado para que funcione correctamente.

- » **Antivirus de pago:** son desarrollados por empresas y suelen ofrecer soporte técnico y actualizaciones periódicas.
- » **Antivirus gratuitos:** aunque suelen tener menos funciones que los de pago, son una buena opción para usuarios que buscan una protección básica de forma gratuita.

Instalar y configurar un antivirus suele ser un proceso relativamente **fácil**. Normalmente, consiste en lo siguiente:

Descarga	Lo bajaremos desde la página oficial del proveedor o un repositorio de confianza.
Instalación	se ejecuta el instalador y seguimos las instrucciones (normalmente, solo hay que hacer clic en <i>Siguiente</i> > <i>Siguiente...</i>).
Reinicio	Reiniciaremos nuestro PC.
Activación	si es necesario, completaremos el registro, normalmente vía email, para obtener una clave de licencia.

Una vez instalado, el antivirus hará un primer escaneo de tu sistema. Un antivirus desactualizado **sirve de poco**. Para ser efectivo, es necesario estar protegido contra las últimas amenazas. En su mayoría, los antivirus tienen actualizaciones automáticas, lo que te ahorra preocupaciones. Es importante diferenciar entre las actualizaciones del software en sí y las de la base de datos. Esta última se refiere a los diferentes tipos de virus, mientras que la primera mejora el rendimiento y la seguridad del programa.

Se debe **escanear el sistema regularmente**. Lo ideal es programar revisiones periódicas (por ejemplo, una vez a la semana). Es mejor no esperar a que tu equipo empiece a fallar para hacer un escaneo, además de añadir siempre los dispositivos externos como USB o discos duros. Aunque este proceso puede tardar varias horas, al ejecutarse en segundo plano se puede hacer sin problemas, ya que podemos seguir trabajando mientras está haciendo el análisis.

Por otra parte, es importante **configurar el antivirus al máximo** para sacarle provecho a este tipo de software. Es necesario ajustar estas opciones:

- » **Frecuencia de escaneos:** revisiones completas cada 15 días.
- » **Actualizaciones automáticas:** el antivirus se debe actualizar diariamente.
- » **Acción ante amenazas:** define si quieres que el antivirus elimine automáticamente los virus o te pida confirmación.
- » **Protección en tiempo real:** actívala para bloquear amenazas antes de que infecten tu equipo.

VIDEO

¿Cómo usar windows defender?: <https://www.youtube.com/watch?v=gk0BtNUv234>

Un antivirus es necesario, pero **no es suficiente**, lo que significa que podemos tomar otras medidas adicionales:

- » **Firewall:** actívalo para bloquear accesos no autorizados.

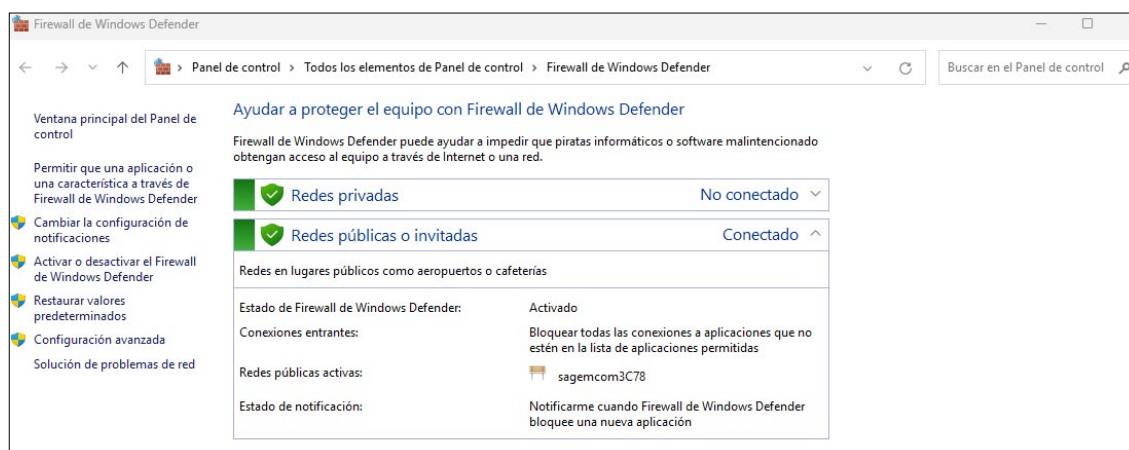


Fig. 12. Actualización del firewall.

- » **Actualizaciones del sistema:** instala siempre los parches de seguridad de tu sistema operativo.

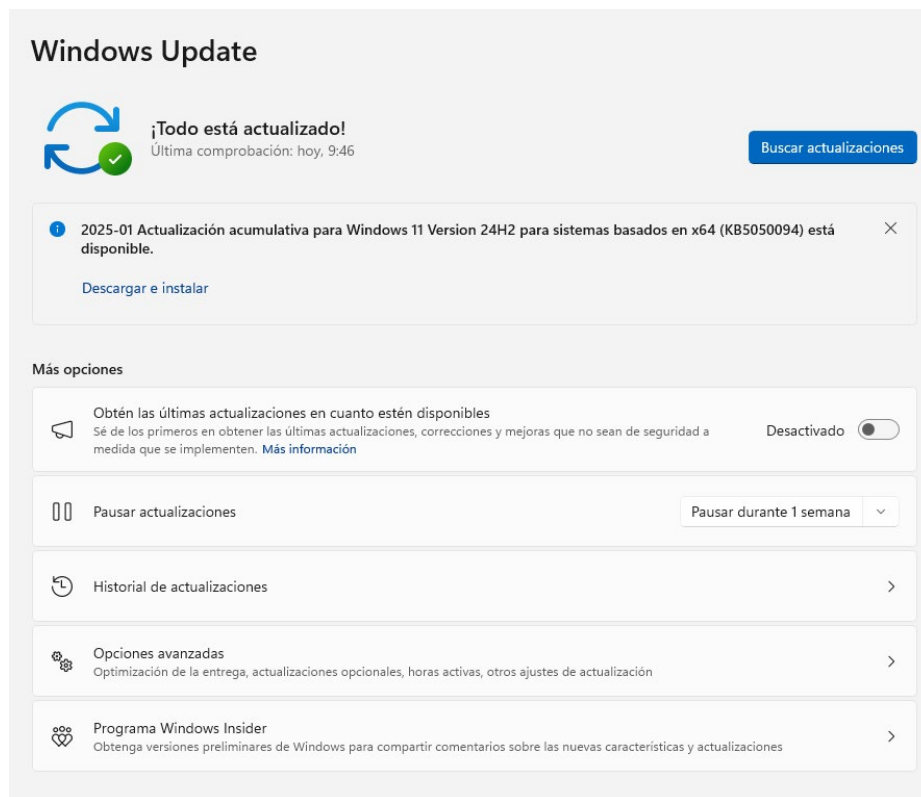


Fig. 13. Actualización del sistema.

- » **Sentido común:** no descargues archivos sospechosos ni abras correos de remitentes desconocidos.

Linux o macOS son menos vulnerables a los virus que Windows, gracias a su arquitectura más segura por usar un modelo de capas. Aunque no es estrictamente necesario instalar un antivirus en estos sistemas, siempre es recomendable mantener buenos hábitos de seguridad, especialmente si hay información sensible.

Proteger tu equipo **no tiene por qué ser ni complicado ni costoso**. Con un buen antivirus, algunas configuraciones básicas y, sobre todo, un poco de atención, puedes estar tranquilo. Recuerda que la seguridad informática es como cerrar la puerta de tu casa al salir. No cuesta nada, pero puede evitarte muchos problemas.

**VIDEOLAB**

Para consultar el siguiente vídeo sobre **Instalación y configuración de Snort en Ubuntu**, escanea el código QR o [pulsa aquí](#).

Aprenderemos a instalar y configurar Snort en Ubuntu. Descubriremos cómo esta herramienta nos permite monitorear el tráfico de red e identificar posibles amenazas. En este caso, vamos a ver cómo detectar que nos hagan un ping desde otra máquina.

3 CASO PRÁCTICO



INSTALACIÓN Y USO DE PROGRAMAS ANTIMALWARE

El objetivo de esta actividad es instalar, actualizar y utilizar tres programas antimalware para comprobar si tu equipo está infectado por algún tipo de software malicioso. Deberás realizar tres capturas de pantalla por cada programa que demuestren los siguientes pasos:

1. Instalación del programa.
2. Comprobación de que la base de datos está actualizada.
3. Resumen de amenazas detectadas después de realizar un análisis completo.

Los programas que utilizarás son:

- » SuperAntispyware.
- » MalwareBytes.
- » AdwCleaner.

Solucionario casos prácticos

1

SOLUCIÓN CASO PRÁCTICO



ELABORACIÓN DE UN PLAN DE CONTINGENCIA PARA UNA PYME DE COMERCIO ELECTRÓNICO

Fase 1: evaluación de riesgos

» Identificación de amenazas:

- Ataques de malware y ransomware.
- Fallos de hardware en servidores críticos.
- Errores humanos en la gestión de datos sensibles.
- Cortes de energía o fallos en la conexión a Internet.

» Impacto de las amenazas:

- Pérdida de datos sensibles de clientes.
- Interrupción de la tienda online, afectando a las ventas.
- Pérdida de confianza de los clientes.

» Recursos afectados:

- Servidores de bases de datos y aplicaciones.
- Ordenadores de empleados.
- Plataforma de pagos en línea.

Fase 2: planificación del plan de contingencia**»» Objetivos:**

- Minimizar el impacto de fallos de seguridad.
- Garantizar la recuperación de la infraestructura en el menor tiempo posible.
- Establecer roles y responsabilidades en caso de incidente.

»» Estrategias de mitigación:

- Implementación de copias de seguridad automatizadas diarias con almacenamiento en la nube y en servidores locales.
- Configuración de un sistema de detección de intrusos (IDS).
- Creación de un equipo de respuesta ante incidentes (CSIRT).

»» Plan de respuesta ante incidentes:

- Notificación inmediata al equipo de TI al detectar anomalías.
- Aislamiento del sistema afectado para evitar la propagación.
- Evaluación del alcance del daño.
- Recuperación de datos a partir de las copias de seguridad más recientes.

Fase 3: pruebas de viabilidad**»» Simulación de ciberataques:**

- Pruebas de intrusión para evaluar la fortaleza de los sistemas.
- Simulaciones de pérdida de datos para verificar tiempos de recuperación.

»» Evaluación de tiempos de recuperación (RTO/RPO):

- RTO (tiempo objetivo de recuperación): 2 horas.
- RPO (punto objetivo de recuperación): 12 horas.

»» Capacitación del personal:

- Talleres sobre identificación de amenazas (phishing, ingeniería social).
- Simulacros de incidentes con participación del equipo de TI y de negocio.

Fase 4: ejecución del plan**»» Pasos iniciales tras detectar un ataque:**

- Desconectar el sistema comprometido de la red.
- Informar al equipo de seguridad.
- Revisar logs para identificar el origen de la brecha.

» Restauración de sistemas:

- Reinstalación del sistema afectado desde backups.
- Cambio de credenciales de acceso y auditoría de seguridad posincidente.

» Comunicación interna y externa:

- Informar a clientes sobre posibles afectaciones de datos.
- Coordinar con proveedores para mitigar impactos operativos.

Fase 5: recuperación y mejora continua

» Evaluación posincidente:

- Análisis forense para identificar la causa raíz del ataque.
- Informe con lecciones aprendidas y mejoras para el futuro.

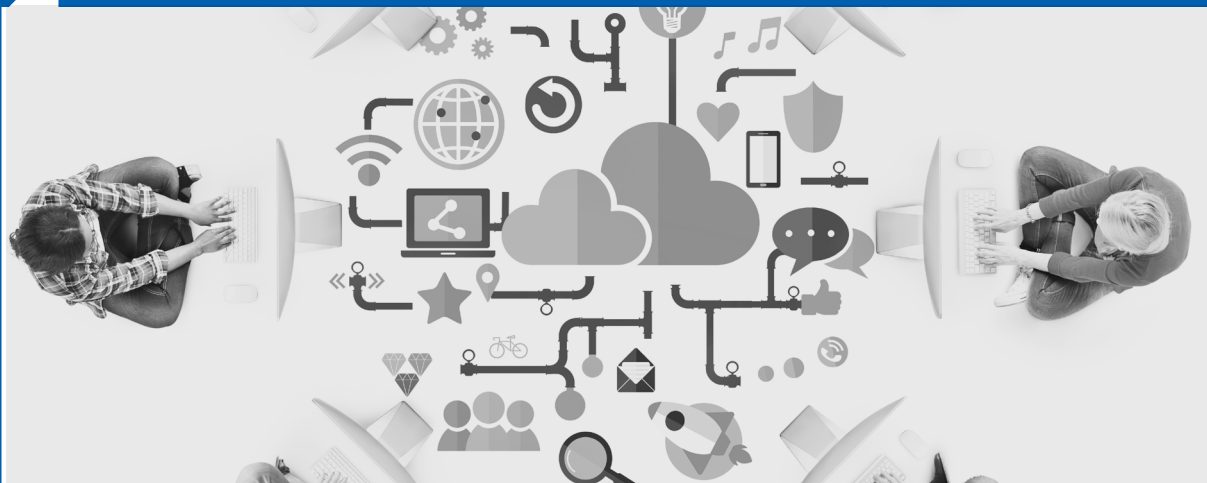
» Actualización del plan de contingencia:

- Incorporación de nuevos riesgos identificados.
- Revisión y actualización semestral del plan.

» Medidas adicionales:

- Implementación de nuevas políticas de seguridad de acceso.
- Mejoras en el monitoreo con alertas más tempranas.

2 SOLUCIÓN CASO PRÁCTICO



USO DE WIRESHARK PARA CAPTURAR TRÁFICO DE VISITAS A UNA PÁGINA WEB

1. Buscamos en Google «login html».
2. Iniciamos sesión con un usuario y password inventado en esta página que no es https.

A screenshot of a web application's login page. The page has a dark grey header with the text 'Publi legal' and 'Iniciar sesión' below it. The main content area is white and contains a login form. The form has a label 'hola' next to a user input field, a password input field with a '*' icon and a masked password '*****', and two buttons: 'Ingresar' (blue) and 'Registrarse' (blue). At the bottom of the form, there is a link '* Recuperar contraseña'.

Archivo Edición Visualización Ir Captura Analizar Estadísticas Telefonía Wireless Herramientas Ayuda					
http					
No.	Time	Source	Destination	Protocol	Length Info
1214	8.576241	192.168.0.19	107.180.119.56	HTTP	528 GET /index.php?r=site/login HTTP/1.1
1329	10.062675	107.180.119.56	192.168.0.19	HTTP	469 HTTP/1.1 200 OK (text/html)
1493	16.488328	192.168.0.19	107.180.119.56	HTTP	726 POST /index.php?r=site/login HTTP/1.1 (application/x-www-form-urlencoded)
1501	16.701764	107.180.119.56	192.168.0.19	HTTP	482 HTTP/1.1 200 OK (text/html)
1505	16.764595	192.168.0.19	142.250.185.3	HTTP	508 GET /s/opensans/v40/memvYaGs126M1Zp8A-UvwbX2vVnXB0bj20VTS2mu1a8.woff2 HTTP/1.1

3. Filtramos con el filtro http.

Time	Source	Destination	Protocol	Length	Info
1214.870241	192.168.0.19	107.188.119.56	HTTP	528	GET /index.php?r=site/login HTTP/1.1
1320.18.082675	107.188.119.56	192.168.0.19	HTTP	469	HTTP/1.1 200 OK (text/html)
1493.16.488320	192.168.0.19	107.188.119.56	HTTP	726	POST /index.php?r=site/login HTTP/1.1 (application/x-www-form-urlencoded)
1501.16.701764	107.188.119.56	192.168.0.19	HTTP	482	HTTP/1.1 200 OK (text/html)
1505.16.764595	192.168.0.19	142.250.185.3	HTTP	588	GET /s/opensans/v40/ewm/yAGs126N12pBA-UvvdX2VvnxKB0bJ20V752mu1a8-worff2 HTTP/1.1

0000	7c 16 89 b2 3c 7c 14 eb	06 95 04 ea 08 00 05 00	[...]
0010	82 c9 5b 99 48 00 00 06	08 de c0 a0 03 6b b4	82 c9 5b 99 48 00 00 06
0020	77 58 00 50 5c 2f	44 6d 45 05 08 0e 50 1b	77 58 00 50 5c 2f
0030	00 ff 76 f3 00 00 50 4f	53 54 20 2f 69 6e 64 65	00 ff 76 f3 00 00 50 4f
0040	78 2e 70 68 70 3f 72 3d	73 69 74 05 2f 6c 6f 67	78 2e 70 68 70 3f 72 3d
0050	69 6c 20 40 14 54 50 2f	31 2c 30 8d 8a 48 4f 73	69 6c 20 40 14 54 50 2f
0060	74 3a 20 70 72 75 65 62	63 64 65 75 73 6f 2e 63	74 3a 20 70 72 75 65 62
0070	6f 6d 0d 0e 55 73 65 72	2d 61 67 65 6e 74 3a 20	6f 6d 0d 0e 55 73 65 72
0080	4d 6f 7a 69 6c 6c 61 2f	35 2e 30 20 28 57 69 6e	4d 6f 7a 69 6c 6c 61 2f
0090	64 6f 77 70 20 44 54 20	31 30 2a 30 30 20 57 69	64 6f 77 70 20 44 54 20
00a0	6e 3a 3a 20 78 36 34	30 20 72 76 3a 31 33 35	6e 3a 3a 20 78 36 34
00b0	2e 30 29 20 47 65 63 6b	6f 2f 32 30 31 30 30 31	2e 30 29 20 47 65 63 6b
00c0	50 31 20 40 69 72 65 66	47 70 2f 31 55 35 2e 30	50 31 20 40 69 72 65 66
00d0	8d 8a 41 63 63 65 70 74	3a 20 74 65 78 74 2f 68	8d 8a 41 63 63 65 70 74
00e0	74 6d 6c 2c 61 70 70 6c	69 63 61 74 69 6f 6e 2f	74 6d 6c 2c 61 70 70 6c
00f0	78 68 74 6d 6c 2b 78 6d	6c 2c 61 70 70 6c 69 63	78 68 74 6d 6c 2b 78 6d
0100	61 74 69 6f 6e 2f 78 6d	6c 3b 71 3d 30 26 39 2c	61 74 69 6f 6e 2f 78 6d
0110	2a 2f 2a 30 71 3d 30 2e	38 6d 8a 61 63 63 65 70	2a 2f 2a 30 71 3d 30 2e
0120	74 2d 4c 61 6e 67 75 61	67 65 3a 20 65 73 2d 45	74 2d 4c 61 6e 67 75 61
0130	53 2c 65 73 30 71 3d 30	2e 30 2c 65 6e 2d 55 53	53 2c 65 73 30 71 3d 30
0140	3b 71 3d 30 2e 35 2c 65	6e 3b 71 3d 30 2e 33 6d	3b 71 3d 30 2e 35 2c 65
0150	8a 41 63 65 70 74 2d	45 6e 63 6f 64 69 6e 67	8a 41 63 65 70 74 2d
0160	3a 20 67 7a 69 70 2c 20	64 65 6c 6c 61 74 65 6d	3a 20 67 7a 69 70 2c 20
0170	8a 43 6f 6e 74 65 6e 74	2d 54 79 70 65 3a 20 61	8a 43 6f 6e 74 65 6e 74
0180	70 70 6c 63 61 74 69	6f 6e 2f 70 2d 77 77	70 70 6c 63 61 74 69
0190	2d 66 6f 72 6d 2d 75 72	6c 65 6e 63 6f 64 65 64	2d 66 6f 72 6d 2d 75 72
01a0	80 8a 43 6f 6e 74 65 6e	74 2d 4c 61 6e 67 74 68	80 8a 43 6f 6e 74 65 6e
01b0	3a 20 37 3d 6d 0a 4f 72	69 6f 69 6e 3a 20 68 74	3a 20 37 3d 6d 0a 4f 72
01c0	74 70 3a 2f 70 72 75	65 62 61 64 65 75 73 6f	74 70 3a 2f 70 72 75
01d0	2e 63 6f 6d 0a 43 6f	6e 2c 65 63 74 69 6f 6e	2e 63 6f 6d 0a 43 6f
01e0	3a 20 65 65 65 70 2d 61	6c 69 76 65 0d 0a 52 65	3a 20 65 65 65 70 2d 61
01f0	66 65 65 65 72 3a 20 68	74 74 70 3a 2f 70 72	66 65 65 65 72 3a 20 68
0200	75 65 62 61 64 65 75 73	6f 2e 63 6f 6d 2f 69 6e	75 65 62 61 64 65 75 73
0210	64 65 78 2e 70 68 70 3f	72 3d 73 69 74 65 2f 6c	64 65 78 2e 70 68 70 3f
0220	6f 6f 6e 6d 0a 43 6f	6f 69 69 65 3a 20 50 68	6f 6f 6e 6d 0a 43 6f
0230	50 53 45 53 53 49 44 3d	37 39 64 66 36 33 39 33	50 53 45 53 53 49 44 3d
0240	30 53 45 53 35 35 62	62 30 53 61 62 61 66 61	30 53 45 53 35 35 62
0250	31 30 38 65 36 66 65 37	8d 8a 55 70 67 72 61 64	31 30 38 65 36 66 65 37
0260	65 2d 49 64 73 65 63 75	72 65 2d 52 65 71 75 65	65 2d 49 64 73 65 63 75
0270	71 74 71 70 78 11 8d 0a	0b 77 69 6f 72 68 74 70	71 74 71 70 78 11 8d 0a
0280	3a 20 75 3d 30 2c 20 69	8d 8a 0d 0a 4c 6f 67 69	3a 20 75 3d 30 2c 20 69
0290	6e 46 6f 73 6d 25 35 42	75 73 65 72 6e 61 6d 65	6e 46 6f 73 6d 25 35 42
02a0	25 35 44 3d 68 6f 6c 61	26 4c 6f 67 69 6e 46 6f	25 35 44 3d 68 6f 6c 61

4. Si exploramos el paquete, podemos ver la web que hemos visitado y el usuario y password que hemos ingresado.

```

HTML Form URL Encoded: application/x-www-form-urlencoded
> Form item: "LoginForm[username]" = "hola"
> Form item: "LoginForm[password]" = "hola1234"
> Form item: "yt0" = "Ingresar"

```

5. ¿Qué diferencias observas entre el tráfico HTTP y HTTPS?

- **HTTP:** el tráfico es visible en texto plano, lo que significa que se pueden leer los datos transmitidos.
- **HTTPS:** el tráfico está cifrado mediante TLS/SSL, por lo que no se puede leer el contenido directamente. Solo se puede ver el handshake inicial y los paquetes cifrados.

6. ¿Cómo identificas la dirección IP del servidor web en los paquetes capturados?

Selecciona un paquete HTTP/HTTPS y revisa el campo *Destination* en la columna *Source* o *Destination*. La dirección IP del servidor será la dirección de destino en las solicitudes (GET) o la dirección de origen en las respuestas (200 OK).

7. ¿Qué información puedes obtener de los encabezados HTTP?

Los encabezados HTTP contienen información como:

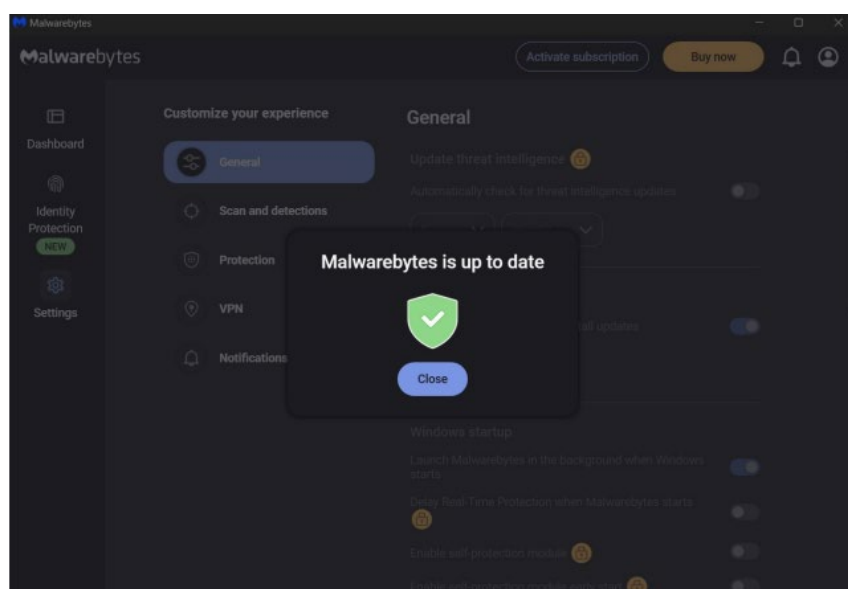
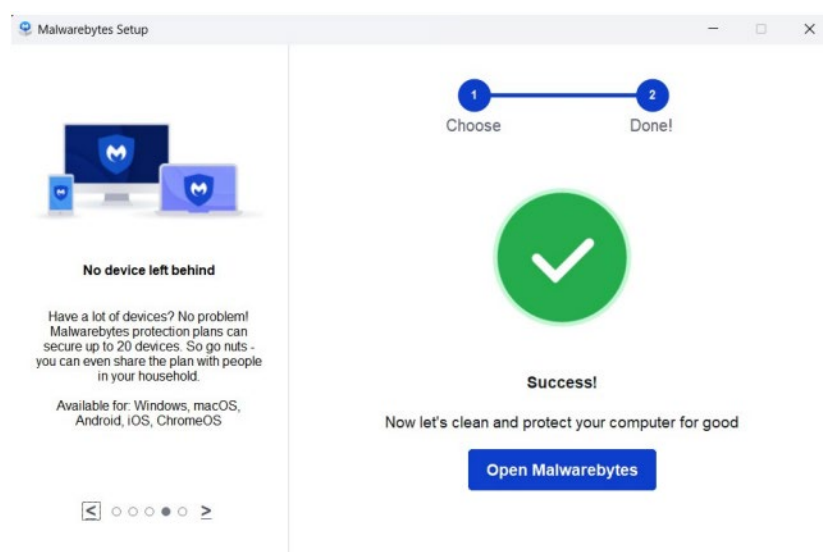
- **Método HTTP:** GET, POST, etc.
- **Ruta del recurso:** Por ejemplo, /index.html.
- **Versión de HTTP:** Por ejemplo, HTTP/1.1.
- **Encabezados de solicitud:** Host, User-Agent, Accept, etc.
- **Encabezados de respuesta:** Content-Type, Content-Length, Server, etc.

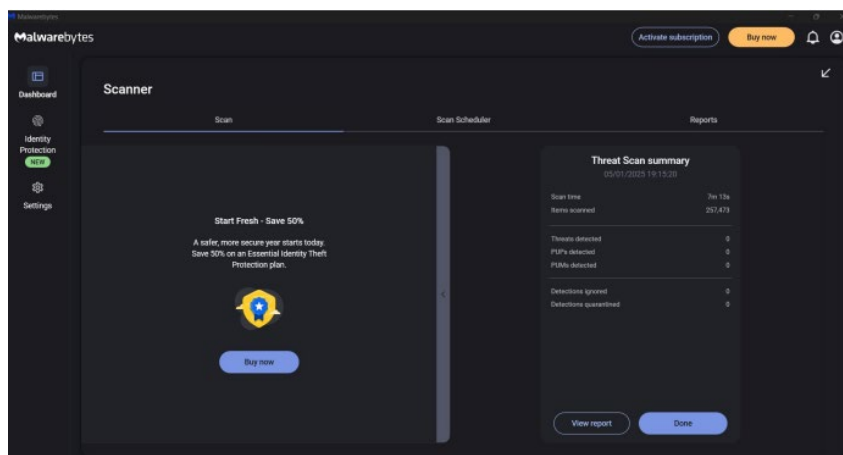
3 SOLUCIÓN CASO PRÁCTICO



INSTALACIÓN Y USO DE PROGRAMAS ANTIMALWARE

1. Instalación:





Enlaces de interés

Vídeo sobre los ciberataques más famosos de la historia:

https://www.youtube.com/watch?v=8-MPekrc_QA

Cómo comprobar la integridad de nuestros archivos con el hash:

<https://www.redeszone.net/tutoriales/seguridad/comprobar-integridad-archivos-hash/>

Cómo verificar el hash de archivos descargados de Internet en Windows 10:

<https://www.youtube.com/watch?v=BZU-bKRSDHY>

DNS spoofing:

<https://www.proofpoint.com/es/threat-reference/dns-spoofing>

Cómo se guardan los archivos en un disco duro:

<https://recuperaciondedatos.com.mx/como-se-guardan-los-archivos-en-un-disco-duro/>

Los 10 mejores programas de recuperación de datos de 2024: características y comparaciones:

<https://www.eltribuno.com/salta/2024-2-28-12-3-0-los-10-mejores-programas-de-recuperacion-de-datos-de-2024-caracteristicas-y-comparaciones>

Encriptación (cifrado) simétrica y asimétrica explicadas fácilmente:

<https://www.youtube.com/watch?v=wDpqrasDmxM>

Todo sobre criptografía: algoritmos de clave simétrica y asimétrica:

<https://www.redeszone.net/tutoriales/seguridad/criptografia-algoritmos-clave-simetrica-asimetrica/>

¿Qué es la firma digital?:

<https://www.proofpoint.com/es/threat-reference/digital-signature>

Información y pasos para la obtención de un certificado electrónico:

<https://sede.agenciatributaria.gob.es/Sede/ayuda/consultas-informaticas/firma-digital-sistema-clave-pin-tecnica/informacion-pasos-obtencion-certificado-electronico.html>

Dónde usar el certificado electrónico:

<https://www.cert.fnmt.es/que-es-ceres/donde-puedo-usar-mi-certificado>

Cómo actualizar Ubuntu: desde escritorio y desde terminal:

<https://www.softzone.es/linux/distros/actualizar-ubuntu/>

Cómo configurar firewall Windows 11:

<https://www.youtube.com/watch?v=LPe21cHHEtA>

Wireshark Fundamentos | Los peligros de los ataques de red | Curso Gratis | Clase 01:

<https://www.youtube.com/watch?v=1wxnyqLFhw&list=PL0tdBnrzjwirRo-1iLwAlleRsfG6MRgps&index=2>

¿Qué es una bomba lógica? Cómo impedir los ataques de bomba lógica:

<https://www.avast.com/es-es/c-what-is-a-logic-bomb>

¿Qué es el hoax o bulo?:

https://www.youtube.com/watch?v=hFeRRCx5g_w

Cómo actuar en caso de un ataque de ransomware:

<https://www.incibe.es/ciudadania/ayuda/ransomware>

Los mejores antivirus gratis para PC:

<https://www.xataka.com/basics/mejores-antivirus-gratis-para-pc>

Cómo descargar e instalar el antivirus Avast 2025 gratis:

<https://www.youtube.com/watch?v=IujRTG1iU6A>

Cómo usar Windows Defender en menos de 5 min:

<https://www.youtube.com/watch?v=gk0BtNUv234>

Glosario

- » **Actualizaciones de seguridad:** Parches o mejoras distribuidas por los fabricantes de software para corregir vulnerabilidades y mejorar la protección del sistema.
- » **Adware:** programa que muestra anuncios publicitarios no deseados, a menudo vinculado con spyware para rastrear la actividad del usuario.
- » **Análisis de comportamiento:** Técnica que detecta actividades sospechosas observando patrones de comportamiento anómalos.
- » **Análisis de riesgos:** Evaluación de amenazas, vulnerabilidades e impactos potenciales para determinar el nivel de riesgo de un sistema.
- » **Análisis de vulnerabilidades:** Proceso de identificación y evaluación de debilidades en un sistema informático.
- » **Análisis forense digital:** Proceso de investigación de incidentes de seguridad para identificar, preservar y analizar la evidencia digital.
- » **Antivirus:** Software diseñado para detectar, prevenir y eliminar software malicioso, como virus, troyanos y gusanos.
- » **Ataque de fuerza bruta:** Método de intrusión que consiste en probar todas las combinaciones posibles de contraseñas hasta encontrar la correcta.
- » **Ataque de ingeniería social:** Estrategia que manipula a las personas para que revelen información confidencial o realicen acciones que comprometan la seguridad.
- » **Auditoría de seguridad:** Evaluación sistemática de la infraestructura de seguridad para identificar deficiencias y proponer mejoras.
- » **Autenticación multifactor (MFA):** Método de verificación de identidad que requiere más de un factor de autenticación para acceder a un sistema.
- » **Autenticidad:** Propiedad que asegura que una aplicación o archivo proviene de una fuente confiable y no ha sido alterado.
- » **Backdoor (puerta trasera):** Método oculto de acceso remoto a un sistema que permite a los atacantes controlarlo sin autorización.

- » **Botnet:** Red de dispositivos infectados controlados de forma remota por un atacante para realizar actividades maliciosas.
- » **Certificado digital:** Documento electrónico que verifica la identidad de una entidad o individuo en el entorno digital.
- » **Configuración del sistema:** Proceso de ajustar las opciones del sistema operativo y las aplicaciones para mejorar la seguridad y el rendimiento.
- » **Contraseña segura:** Combinación de caracteres alfanuméricos y símbolos que dificulta su descifrado mediante ataques de fuerza bruta.
- » **Control de acceso:** Políticas y mecanismos que regulan quién puede acceder a los recursos de un sistema y en qué condiciones.
- » **Copias de seguridad (backups):** Procedimientos de duplicación de datos para garantizar su recuperación en caso de pérdida o daño.
- » **Cross-Site Scripting (XSS):** Vulnerabilidad que permite a los atacantes inyectar código malicioso en sitios web visitados por otros usuarios.
- » **Cryptojacking:** Uso no autorizado de los recursos de un sistema para minar criptomonedas.
- » **Denegación de servicio (DoS):** Ataque que busca saturar los recursos de un sistema o red, dejándolo inoperativo para usuarios legítimos.
- » **Dropper:** Programa diseñado para instalar malware en un sistema, generalmente sin ser detectado.
- » **Escalamiento de privilegios:** Técnica utilizada por atacantes para obtener niveles de acceso más altos de los que originalmente poseen.
- » **Escaneo de seguridad:** Evaluación automática del sistema para detectar vulnerabilidades y amenazas potenciales.
- » **Exploit:** Fragmento de código que aprovecha vulnerabilidades en el software para ejecutar acciones maliciosas.
- » **Extensiones de archivo:** Sufijos al final del nombre de un archivo que indican su tipo, como .exe para ejecutables o .docx para documentos de texto.
- » **Firewall (cortafuegos):** Sistema de seguridad que regula el tráfico de red entrante y saliente según reglas predefinidas, protegiendo el sistema contra accesos no autorizados.

- » **Firmware malicioso:** Malware que afecta al firmware de un dispositivo, permitiendo un control profundo del hardware.
- » **Flooding:** Ataque que consiste en enviar grandes cantidades de tráfico a un sistema para saturarlo y hacerlo inaccesible.
- » **Gestor de contraseñas:** Herramienta que almacena y administra de forma segura las contraseñas de un usuario.
- » **Gestor de incidentes:** Persona o herramienta responsable de coordinar la respuesta ante incidentes de seguridad.
- » **Gusano (worm):** Malware que se replica y propaga automáticamente a través de redes, sin necesidad de intervención del usuario.
- » **Hash:** Valor numérico generado a partir de datos de entrada, utilizado para verificar la integridad de archivos y contraseñas.
- » **Hijacking:** Técnica que permite a un atacante tomar el control de una sesión activa o de un sistema sin el conocimiento del usuario.
- » **Hoax:** Mensaje falso o engañoso que se difunde para provocar alarma o manipular el comportamiento de los usuarios.
- » **IDS (Intrusion Detection System):** Sistema de detección de intrusos que monitoriza el tráfico de red en busca de actividades sospechosas.
- » **Ingeniería social:** Técnica utilizada para manipular psicológicamente a las personas y obtener información confidencial.
- » **Integridad:** Garantía de que los datos no han sido modificados o alterados de forma no autorizada.
- » **Intrusión:** Acceso no autorizado a un sistema informático con el objetivo de obtener, modificar o destruir información.
- » **IPS (Intrusion Prevention System):** Sistema de prevención de intrusos que no solo detecta, sino que también bloquea actividades maliciosas.
- » **Keylogger:** Software que registra las pulsaciones del teclado del usuario para capturar información confidencial, como contraseñas.

- » **Malware:** Término general que engloba todo tipo de software malicioso diseñado para dañar, explotar o comprometer sistemas informáticos.
- » **Man-in-the-Middle (MitM):** Ataque en el que un tercero intercepta y, posiblemente, altera la comunicación entre dos partes.
- » **Mitigación:** Acciones destinadas a reducir el impacto de un incidente de seguridad o una vulnerabilidad.
- » **Parche de seguridad:** Actualización de software diseñada para corregir vulnerabilidades o errores de seguridad.
- » **Phishing:** Técnica de fraude que busca engañar a los usuarios para obtener información confidencial, como contraseñas o datos bancarios.
- » **Phishing:** Técnica de fraude que busca obtener información confidencial, como contraseñas o datos bancarios, mediante el engaño al usuario.
- » **Planes de contingencia:** Conjunto de procedimientos planificados para responder a incidentes de seguridad, minimizar daños y recuperar la operatividad del sistema.
- » **Privilegios de usuario:** Permisos asignados a los usuarios que determinan qué acciones pueden realizar en un sistema informático.
- » **Privilegios mínimos:** Principio de seguridad que establece que los usuarios deben tener solo los permisos estrictamente necesarios para realizar sus tareas.
- » **Ransomware:** Malware que cifra los archivos del usuario y exige un rescate para restaurar el acceso a la información.
- » **Registro de eventos (logs):** Archivos que registran la actividad de un sistema, utilizados para la detección y el análisis de incidentes.
- » **Resiliencia:** Capacidad de un sistema para recuperarse rápidamente tras un incidente de seguridad o una interrupción del servicio.
- » **Restauración del sistema:** Proceso de devolver un sistema comprometido a su estado operativo normal tras un incidente de seguridad.
- » **Rootkit:** Conjunto de herramientas diseñadas para ocultar la presencia de malware en un sistema comprometido, dificultando su detección.

- » **Scareware:** Software que engaña al usuario haciéndole creer que su equipo está infectado para que adquiera programas innecesarios.
- » **Segmentación de red:** División de una red en subredes más pequeñas para limitar la propagación de amenazas.
- » **Seguridad activa:** Conjunto de medidas y herramientas destinadas a prevenir ataques y minimizar los efectos de amenazas en los sistemas informáticos.
- » **Seguridad en capas:** Estrategia de defensa que aplica múltiples controles de seguridad para proteger un sistema.
- » **Sistema operativo:** Software que gestiona los recursos de hardware y permite la ejecución de aplicaciones en un dispositivo.
- » **Sistemas operativos propietarios:** Sistemas informáticos cuyo código fuente está protegido y no puede ser modificado libremente, como Windows.
- » **Sniffer:** Herramienta que captura y analiza el tráfico de red, pudiendo utilizarse para fines legítimos o maliciosos.
- » **Software libre:** Programas cuyo código fuente está disponible para ser modificado y distribuido libremente, como Linux.
- » **Spam:** Correos electrónicos no solicitados que se envían de forma masiva, generalmente con fines publicitarios o maliciosos.
- » **Spyware:** Software malicioso que recopila información personal del usuario sin su consentimiento y la envía a terceros.
- » **SQL Injection:** Técnica de ataque que inserta código SQL malicioso en formularios web para acceder o manipular bases de datos.
- » **Token de seguridad:** Dispositivo o software que genera códigos únicos para la autenticación segura del usuario.
- » **Troyano:** Programa malicioso que se oculta dentro de aplicaciones aparentemente legítimas para facilitar el acceso no autorizado a un sistema.
- » **Vulnerabilidad:** Debilidad en un sistema informático que puede ser explotada por los atacantes para comprometer su seguridad.

Bibliografía

Brooks, C. J., Grow, C., Craig, P. y Short D. (2018). *Cybersecurity Essentials*. Sybex.

Davis, R. (2020). *The Art of Network Penetration Testing: How to Take Over Any Company in the World*. Manning.

Murdoch, D. (2014). *Blue Team Handbook*. Incident Response Edition.

Pfleeger, C. P. y Pfleeger, S. L. (2015). *Security in Computing*. Pearson.

Postigo Palacios, A. (2020). *Seguridad Informática*. Paraninfo.

Stallings, W. (2017). *Cryptography and Network Security: Principles and Practice*. Pearson.

X T A R T
FP TECH